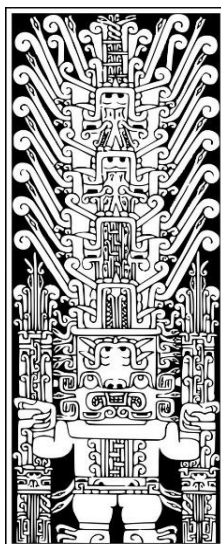


UNIVERSIDAD NACIONAL FEDERICO VILLARREAL

FACULTAD DE INGENIERIA INDUSTRIAL Y DE SISTEMAS

ESCUELA PROFESIONAL DE INGENIERIA DE SISTEMAS



INCIDENTES DE CIBERSEGURIDAD

ALUMNO:

Benites Meza, Marco Fabricio

Dongo Villarreal Piero Kotaro

Mendoza Ccanto Bryan William

Mendoza Guzman Luis Eduardo

DOCENTE:

Dr. Frayssinet Delgado, Maurice Victor

Lima, 2026

Resumen Ejecutivo

El presente proyecto aplica la Dinámica de Sistemas para modelar el comportamiento de los incidentes de ciberseguridad en una organización del sector financiero. El modelo busca explicar por qué las estrategias reactivas tradicionales (inversión en tecnología solo después de un ataque) resultan insuficientes frente a la evolución de las amenazas, generando ciclos de "pánico y relajación" que perpetúan la vulnerabilidad.

A través de la simulación, se identificó que el **tiempo de respuesta (MTTR)** y la **tasa de parcheo** son las variables más sensibles del sistema. El análisis revela un bucle de refuerzo dominante donde los incidentes generan inversión apresurada, pero al no reducir la vulnerabilidad estructural, el problema se agrava. El escenario base proyecta un colapso del sistema en el mes 36, con costes acumulados que superan el 40% del presupuesto de TI. Sin embargo, reducir el MTTR de 6 a 1 mes disminuye los incidentes exitosos en un 40%.

Como política de intervención, se propone un **modelo híbrido de IA y Gemelo Digital** que automatiza la detección de anomalías y permite probar parches en un entorno virtual. La simulación de este escenario muestra una reducción del daño acumulado en un 60%, transformando la dinámica del sistema de un comportamiento oscilatorio y colapsante a un estado de equilibrio controlado. El proyecto concluye que la ciberseguridad efectiva requiere sincronizar la velocidad de respuesta, la inteligencia predictiva y la capacitación continua, rompiendo el ciclo de "inversión por pánico" que caracteriza a la industria.

Introducción

En la última década, la transformación digital ha impulsado a las organizaciones a adoptar infraestructuras tecnológicas cada vez más complejas, interconectadas y dependientes de datos. Sin embargo, esta evolución ha traído consigo un incremento paralelo en la superficie de ataque expuesta a ciberdelincuentes. Según reportes de organismos internacionales, los incidentes de ciberseguridad han crecido a una tasa anual superior al 15% a nivel global, con costes estimados que superan los 10 billones de dólares para 2025. Más allá de las cifras, lo preocupante es el **comportamiento dinámico** de estos incidentes: no siguen un patrón lineal ni predecible, sino que presentan picos explosivos, oscilaciones y, en muchos casos, colapsos súbitos de los sistemas de defensa.

La Dinámica de Sistemas, metodología fundada por Jay W. Forrester en la década de 1960, ofrece un marco teórico y práctico para comprender este tipo de problemas. Al modelar los bucles de retroalimentación, los retrasos y las no linealidades, permite visualizar cómo las decisiones de corto plazo generan consecuencias no deseadas en el largo plazo. En el ámbito de la ciberseguridad, esta aproximación es particularmente relevante porque los ataques no son eventos aislados, sino que responden a la evolución adaptativa de los atacantes, quienes modifican sus tácticas en función de las defensas implementadas, generando una dinámica de "carrera armamentista" (buque de refuerzo) que solo puede ser estabilizada mediante políticas proactivas y predictivas.

El presente proyecto se centra en modelar este comportamiento dinámico aplicado a una organización del sector financiero, uno de los sectores más regulados y atacados a nivel mundial. A través de la construcción de un modelo de simulación, se busca responder a las siguientes preguntas de investigación:

- ¿Cómo evoluciona el número de incidentes exitosos en función de la inversión en seguridad y el tiempo de respuesta?
- ¿Qué variables generan mayor sensibilidad en el sistema y, por tanto, representan las mejores palancas de intervención?
- ¿Es posible estabilizar el sistema mediante políticas híbridas que combinen inteligencia artificial y gemelos digitales?

Para ello, se desarrolla un modelo stock-flow que integra variables como la tasa de parcheo, el tiempo medio de respuesta (MTTR), el nivel de vulnerabilidad y el daño acumulado. El modelo es validado mediante pruebas de comportamiento extremo y análisis de sensibilidad, y se simulan tres escenarios: un escenario base (reactivo), un escenario de inversión constante y un escenario proactivo con IA predictiva y gemelo digital.

La estructura del informe sigue la metodología estándar de la Dinámica de Sistemas: comenzamos con la identificación del problema dinámico, la justificación del enfoque sistémico, los objetivos y el alcance. Luego presentamos las variables clave, las gráficas de comportamiento en el tiempo (BOT), el diagrama causal, los bucles de retroalimentación y los arquetipos identificados. A continuación, desarrollamos el modelo stock-flow con sus ecuaciones y parámetros, y presentamos los resultados de la simulación, incluyendo el análisis de sensibilidad y la comparación de escenarios. Finalmente, se proponen políticas de intervención, se discuten

las implicaciones para la gestión de la ciberseguridad y se formulan recomendaciones concretas para los tomadores de decisiones.

Con este enfoque, el proyecto no solo contribuye al entendimiento académico de la dinámica de los incidentes de ciberseguridad, sino que también ofrece una herramienta práctica para que las organizaciones puedan anticipar riesgos, optimizar sus inversiones y construir una postura de seguridad más resiliente en un entorno de amenazas en constante evolución.

Descripción del problema dinámico

El problema que aborda este proyecto no es un incidente aislado de ciberseguridad, sino el **comportamiento recurrente y tendencial** que presentan los incidentes exitosos a lo largo del tiempo en una organización. Desde la perspectiva de la Dinámica de Sistemas, un problema se considera *dinámico* cuando su evolución no puede explicarse mediante relaciones simples de causa-efecto, sino que responde a la interacción de múltiples variables que cambian con el tiempo, generando patrones como crecimiento exponencial, oscilaciones, saturación o colapso.

En el caso de la ciberseguridad, el problema dinámico se manifiesta en las siguientes dimensiones:

a) Crecimiento acelerado de los incidentes

Durante los últimos cinco años, el número de incidentes de seguridad reportados por el sector financiero ha crecido a una tasa compuesta anual superior al 20%. Este crecimiento no es lineal: los ataques de ransomware, las filtraciones de datos y los accesos no autorizados se han duplicado en períodos cada vez más cortos, impulsados por la digitalización forzada (post-pandemia) y la sofisticación de las técnicas de ingeniería social. La gráfica BOT elaborada en este proyecto (ver punto 10) muestra una curva exponencial para los incidentes exitosos, lo que indica que, en ausencia de intervenciones estructurales, el sistema tiende a un punto de colapso.

b) Retrasos estructurales (delays)

El sistema de defensa presenta múltiples retrasos que distorsionan la efectividad de las políticas de seguridad:

- **Retraso en la detección:** El tiempo medio para identificar una brecha activa puede oscilar entre días y meses (según el informe de IBM, el promedio global es de 277 días). Durante este período, el atacante tiene libertad para moverse lateralmente en la red.
- **Retraso en el parcheo:** Una vez identificada una vulnerabilidad crítica, el tiempo para desarrollar, probar y desplegar el parche en todos los sistemas puede superar las 72 horas, mientras que los atacantes explotan esa ventana en menos de 24 horas.
- **Retraso en la inversión efectiva:** Las decisiones de asignación presupuestaria suelen tomarse en ciclos anuales, mientras que las amenazas evolucionan diariamente. Esto genera un desfase permanente entre el riesgo real y la capacidad de respuesta.

c) Acumulación de vulnerabilidades (stock)

Las vulnerabilidades no desaparecen por sí solas; se acumulan en el sistema. Cada nuevo descubrimiento de fallo de seguridad (CVE) se suma al stock existente, y solo una fracción de ellas es parcheada a tiempo. Esta acumulación genera un "pasivo técnico" que incrementa la

probabilidad de éxito de cualquier ataque futuro, creando un efecto de bola de nieve que refuerza la exposición al riesgo.

d) Comportamiento adaptativo de los atacantes (no linealidad)

A diferencia de los sistemas físicos, los atacantes aprenden y se adaptan. Cuando una organización implementa un firewall de nueva generación, los ciberdelincuentes cambian sus tácticas hacia el phishing o la explotación de identidades. Esta co-evolución genera una **no linealidad** fundamental: la efectividad de las defensas no es proporcional al gasto en tecnología, sino que sigue una curva de rendimientos decrecientes. Es decir, duplicar la inversión no duplica la seguridad; más allá de un punto, el esfuerzo adicional produce mejoras marginales cada vez menores.

e) Oscilaciones inducidas por la gestión reactiva

Las organizaciones suelen alternar entre períodos de baja inversión (cuando no ha habido incidentes) y períodos de alta inversión (inmediatamente después de un ataque grave). Esta conducta genera oscilaciones en el nivel de vulnerabilidad: la vulnerabilidad baja temporalmente después de la inversión, pero al relajarse las medidas, vuelve a subir, dando lugar a un ciclo de "pánico y calma" que es ineficiente y costoso.

Hipótesis fundamental

La hipótesis central de este proyecto es que **el comportamiento observado (crecimiento exponencial de incidentes) es causado por la interacción entre los retrasos en la respuesta y un bucle de refuerzo donde los incidentes generan una falsa sensación de urgencia, que deriva en inversiones mal orientadas, que no reducen la vulnerabilidad estructural, perpetuando así el ciclo de ataques exitosos.** Para romper esta dinámica, es necesario identificar las palancas de mayor apalancamiento en este caso, el tiempo de respuesta (MTTR) y la automatización del parche y diseñar políticas que actúen sobre ellas de manera proactiva, antes de que los incidentes se manifiesten.

Justificación del uso de Dinámica de Sistemas

La elección de la Dinámica de Sistemas como metodología de modelado para este proyecto no es arbitraria, sino que responde a las características intrínsecas del problema de los incidentes de ciberseguridad, que lo hacen particularmente adecuado para este enfoque. A continuación, se detallan las razones que justifican su aplicación:

a) Naturaleza dinámica y no lineal del problema

Como se describió en el punto anterior, los incidentes de ciberseguridad no siguen un comportamiento lineal ni predecible. Los ataques no se distribuyen uniformemente en el tiempo, sino que presentan picos explosivos, períodos de relativa calma y cambios abruptos en la tasa de éxito. La Dinámica de Sistemas está diseñada específicamente para modelar este tipo de comportamientos no lineales, capturando las relaciones de causa-efecto que generan dichos patrones. Mientras que los modelos estadísticos tradicionales se limitan a describir correlaciones, la Dinámica de Sistemas permite explicar *por qué* ocurren estos comportamientos, identificando los bucles de retroalimentación subyacentes.

b) Importancia crítica de los retrasos (delays)

Uno de los hallazgos clave en la gestión de la ciberseguridad es que los retrasos en la detección, el parcheo y la toma de decisiones son factores determinantes del éxito o fracaso de las defensas. La Dinámica de Sistemas incorpora explícitamente los retrasos como elementos estructurales del modelo, permitiendo simular cómo un retraso de 24 horas en el parcheo puede traducirse en una brecha de seguridad meses después. Esta capacidad es fundamental para evaluar el impacto de políticas como la automatización o la reducción del MTTR (Mean Time to Respond).

c) Interdependencia de variables y bucles de retroalimentación

En ciberseguridad, las variables no actúan de forma aislada. Por ejemplo, un aumento de incidentes genera una mayor inversión en seguridad, pero esa inversión tarda en traducirse en una reducción de la vulnerabilidad, y durante ese retraso, los atacantes pueden haber evolucionado sus tácticas. Este tipo de interacciones crea bucles de retroalimentación (tanto de refuerzo como de balance) que solo pueden ser capturados mediante un enfoque sistémico. La Dinámica de Sistemas proporciona las herramientas (diagramas causales, diagramas de Forrester) para representar y analizar estos bucles de manera explícita.

d) Capacidad de simulación de escenarios "qué pasaría si"

Una de las limitaciones de los enfoques tradicionales de seguridad es que las decisiones se toman basándose en la experiencia pasada o en el cumplimiento de normativas, sin una comprensión clara de las consecuencias a largo plazo. La Dinámica de Sistemas permite construir un modelo computacional que simula el comportamiento del sistema bajo diferentes políticas, como aumentar el presupuesto, reducir el tiempo de respuesta o implementar IA predictiva. Esto convierte al modelo en un **laboratorio virtual** donde los tomadores de decisiones pueden probar sus hipótesis sin poner en riesgo la infraestructura real.

e) Identificación de puntos de apalancamiento

La metodología sistémica no solo describe el problema, sino que ayuda a identificar las variables con mayor capacidad de influir en el sistema (puntos de apalancamiento). En este proyecto, el análisis de sensibilidad revelará qué parámetros generan el mayor impacto en la reducción de incidentes, permitiendo priorizar inversiones y esfuerzos de manera más efectiva que los enfoques intuitivos.

f) Enfoque en la estructura, no en los eventos

La Dinámica de Sistemas se diferencia de otros enfoques porque se centra en la **estructura** del sistema (las relaciones causales, los flujos y las acumulaciones) en lugar de en los eventos aislados. En ciberseguridad, esto es crucial: un ataque exitoso (evento) es solo el síntoma visible de una estructura subyacente de vulnerabilidades acumuladas, retrasos en la respuesta y decisiones mal sincronizadas. Abordar la estructura permite diseñar soluciones duraderas, en lugar de simplemente reaccionar a los síntomas.

g) Aplicación demostrada en problemas socio-técnicos complejos

La Dinámica de Sistemas ha sido ampliamente utilizada en ámbitos donde interactúan personas, tecnología y procesos, como la gestión hospitalaria, la logística, la economía y, más recientemente, la ciberseguridad (ej. modelos de propagación de malware, dinámicas de confianza digital). Su eficacia en estos dominios valida su pertinencia para abordar el problema de los incidentes de ciberseguridad desde una perspectiva integral.

Objetivos del proyecto

Objetivo General

Construir un modelo de simulación en Dinámica de Sistemas que represente la evolución temporal de los incidentes de ciberseguridad en una organización del sector financiero, con el fin de identificar las variables críticas que determinan su comportamiento y evaluar el impacto de diferentes políticas de intervención para reducir la vulnerabilidad estructural y el daño acumulado.

Objetivos Específicos

1. **Identificar y caracterizar las variables clave** que influyen en la dinámica de los incidentes de ciberseguridad, incluyendo la tasa de ataques, el nivel de vulnerabilidad, el tiempo de respuesta (MTTR), la inversión en seguridad y la capacitación del personal, así como sus interdependencias causales.
2. **Construir gráficas de comportamiento en el tiempo (BOT)** que representen la evolución histórica y proyectada de los incidentes exitosos, la vulnerabilidad del sistema y el daño acumulado, permitiendo visualizar los patrones de crecimiento, oscilación o saturación que caracterizan el problema.
3. **Desarrollar el modelo estructural del sistema** mediante un diagrama causal y un diagrama de niveles y flujos (stock-flow) que capture explícitamente los retrasos en la detección y parcheo, los bucles de retroalimentación (refuerzo y balance) y los arquetipos sistémicos presentes, como el de "soluciones que fallan".
4. **Simular el escenario base** del modelo para reproducir el comportamiento actual de la organización sin políticas proactivas, validando la capacidad del modelo para replicar las tendencias observadas en los datos históricos y en la literatura especializada.
5. **Realizar un análisis de sensibilidad** para identificar los parámetros con mayor influencia en los resultados del modelo, determinando así los puntos de apalancamiento sobre los cuales deben enfocarse las estrategias de mitigación.
6. **Diseñar y evaluar escenarios alternativos de intervención**, incluyendo una política reactiva (inversión post-incidente), una política de inversión constante y una política proactiva basada en inteligencia artificial y gemelo digital, comparando su efectividad en la reducción de incidentes y costes asociados.
7. **Formular recomendaciones estratégicas** para los tomadores de decisiones de la organización, basadas en los resultados de la simulación, que permitan optimizar la asignación de recursos, reducir los tiempos de respuesta y fortalecer la resiliencia del sistema frente a amenazas en evolución.

Alcance y frontera del sistema

La definición del alcance y la frontera del sistema es un paso crítico en la construcción de cualquier modelo de Dinámica de Sistemas, ya que determina qué variables, relaciones y actores serán considerados dentro del modelo y cuáles quedarán fuera, perteneciendo al entorno. Esta delimitación permite mantener la complejidad del modelo en un nivel manejable sin perder relevancia para el problema planteado.

Alcance del modelo

El modelo se centra en el comportamiento de los incidentes de ciberseguridad en una **organización del sector financiero de tamaño mediano**, con una infraestructura tecnológica que incluye redes internas, servidores de datos, aplicaciones bancarias y dispositivos de usuario final (empleados). El horizonte temporal de la simulación es de **60 meses (5 años)**, con un paso de integración mensual, lo que permite capturar tanto las tendencias a largo plazo como los efectos de los retrasos operativos.

Dentro del alcance del modelo se consideran las siguientes dinámicas:

- **Ataques externos:** Se modela la tasa de ataques entrantes (malware, ransomware, phishing, exploits de día cero) como una variable exógena que puede variar según escenarios.
- **Vulnerabilidades internas:** Se incluye la acumulación de vulnerabilidades no parcheadas, tanto las descubiertas por el equipo de seguridad como las reportadas por proveedores externos.
- **Capacidad de respuesta:** Se modela el tiempo medio de respuesta (MTTR) y la tasa de parcheo, así como su dependencia de la inversión en personal y herramientas.
- **Inversión en seguridad:** Se considera la asignación presupuestaria para tecnología, capacitación y contratación de personal, distinguiendo entre inversión reactiva (post-incidente) y proactiva (planificada).
- **Daño acumulado:** Se cuantifica el impacto económico y reputacional de los incidentes exitosos, que a su vez influye en las decisiones de inversión futura.
- **Factor humano:** Se incluye el nivel de capacitación y concienciación de los empleados como variable que modifica la efectividad de los ataques de ingeniería social.

Frontera del sistema (límites)

La frontera del sistema establece qué elementos son considerados **endógenos** (dentro del modelo) y cuáles **exógenos** (parte del entorno). Esta delimitación es fundamental para evitar que el modelo se vuelva inabordable y para centrar el análisis en las variables que la organización puede influir directamente.

Endógenos (dentro del sistema)	Exógenos (entorno / fuera del sistema)
Nivel de vulnerabilidad del sistema	Tasa global de ciberataques (macro)
Tasa de parcheo de vulnerabilidades	Políticas gubernamentales y regulaciones (ej. GDPR)
Tiempo de respuesta (MTTR)	Actividades de grupos de ciberdelincuencia (geopolítica)

Inversión en seguridad (reactiva y proactiva)	Avances tecnológicos disruptivos (ej. computación cuántica)
Capacitación del personal	Cambios en el mercado de seguros cibernéticos
Incidentes exitosos (brechas)	Condiciones macroeconómicas (inflación, tipo de cambio)
Daño acumulado (económico y reputacional)	Competencia y presión del mercado
Presupuesto asignado a ciberseguridad	Normativas sectoriales específicas (ej. circular SBS)

Delimitación temporal y espacial

- Temporal:** El modelo cubre el período 2024-2029, utilizando datos históricos de incidentes (2020-2023) para la calibración inicial. No se consideran eventos catastróficos de baja probabilidad (ej. guerra cibernética a gran escala) que escapen al horizonte de planificación típico de la organización.
- Espacial:** El modelo se limita a la organización objetivo, sin incluir interacciones con otras entidades del ecosistema financiero (ej. cámaras de compensación, otras entidades bancarias) salvo que se indique explícitamente en escenarios de simulación.

Actores y elementos del sistema

La ciberseguridad en una organización no es únicamente un problema tecnológico, sino un **sistema socio-técnico** donde interactúan personas, procesos y tecnología. Identificar claramente a los actores y elementos que participan en el sistema es fundamental para comprender cómo sus decisiones y comportamientos influyen en la dinámica de los incidentes. A continuación, se describen los principales actores y elementos que forman parte del modelo.

Actores del sistema

Actores internos (dentro de la organización)

Actor	Rol en el sistema	Influencia sobre variables clave
Equipo de Seguridad (CISO, analistas, ingenieros)	Responsable de detectar amenazas, gestionar parches, responder a incidentes y proponer inversiones en seguridad. Su eficiencia determina el tiempo de respuesta (MTTR) y la tasa de parcheo.	Reduce la vulnerabilidad, acorta el MTTR, incrementa la efectividad de la inversión.
Empleados (usuarios finales)	Principal eslabón débil en la cadena de seguridad. Su nivel de concienciación y cumplimiento de políticas (ej. no abrir enlaces sospechosos) influye en la tasa de éxito de ataques de ingeniería social (phishing).	Afecta directamente la tasa de incidentes exitosos y la efectividad de la capacitación.

Directiva / Gerencia de TI	Toma decisiones de asignación presupuestaria, aprueba políticas de seguridad y define la estrategia de inversión (reactiva o proactiva). Su percepción del riesgo determina el flujo de inversión en seguridad.	Controla la inversión en seguridad, la contratación de personal y la priorización de proyectos.
Audidores internos / Cumplimiento	Supervisan el cumplimiento de normativas (ISO 27001, PCI-DSS, GDPR) y generan reportes que pueden acelerar o retrasar la implementación de parches críticos.	Influyen en la presión para parchear vulnerabilidades y en la asignación de recursos.
Usuarios externos (clientes)	Aunque no participan directamente en la defensa, su percepción de confianza se ve afectada por los incidentes, lo que impacta en la reputación y, por tanto, en el daño acumulado.	Su comportamiento (ej. retiro de fondos, quejas) amplifica el daño reputacional.

Actores externos (fuera de la organización)

Actor	Rol en el sistema	Influencia sobre variables clave
Ciberdelincuentes (hackers, grupos APT)	Generan la amenaza externa. Su evolución táctica (nuevos vectores de ataque, exploits de día cero) modifica la tasa de ataques y la efectividad de las defensas existentes.	Incrementan la tasa de ataques y la dificultad de detección.
Proveedores de soluciones de seguridad	Ofrecen herramientas (firewalls, SIEM, EDR) y servicios de inteligencia de amenazas. Su calidad y tiempo de actualización influyen en la capacidad de respuesta.	Afectan la efectividad de la inversión y la velocidad de parcheo.
Reguladores / Entes supervisores (ej. SBS, INDECOPI)	Establecen normativas que obligan a la organización a mantener ciertos estándares de seguridad y a reportar incidentes.	Generan presión para invertir en seguridad y reducir el tiempo de exposición.
Medios de comunicación	Amplifican el daño reputacional al difundir noticias sobre incidentes, lo que presiona a la directiva para reaccionar rápidamente.	Aumentan el daño acumulado y aceleran la inversión reactiva.

Elementos del sistema

Los elementos representan los **recursos físicos, tecnológicos, financieros e intangibles** que intervienen en el sistema y que son gestionados por los actores.

Elemento	Descripción	Relación con el modelo
Infraestructura tecnológica	Servidores, equipos de red, endpoints (laptops, móviles), aplicaciones bancarias y bases de datos. Constituyen la superficie de ataque.	Determina el stock de vulnerabilidades y la exposición a ataques.
Datos / Activos de información	Información sensible de clientes, transacciones, propiedad intelectual. Son el objetivo principal de los atacantes.	Su pérdida o exposición genera el daño acumulado.
Herramientas de seguridad	Firewalls, antivirus, sistemas de detección de intrusiones (IDS/IPS), SIEM, plataformas de respuesta a incidentes (SOAR).	Su calidad y actualización afectan la tasa de detección y la efectividad de la inversión.
Presupuesto	Recursos financieros asignados anualmente a ciberseguridad. Su magnitud y distribución determinan la capacidad de contratación, compra de herramientas y capacitación.	Variable central que alimenta todos los flujos de mejora (parcheo, contratación, capacitación).
Conocimiento / Capacitación	Nivel de competencia del equipo de seguridad y concienciación de los empleados.	Determina la velocidad de respuesta y la reducción del error humano.
Políticas y procedimientos	Normas internas sobre gestión de parches, respuesta a incidentes, acceso a datos y uso aceptable de tecnología.	Su claridad y cumplimiento afectan los retrasos en la respuesta y la eficiencia operativa.
Reputación	Activo intangible que se ve afectado por los incidentes. Su pérdida reduce la confianza de clientes e inversores, generando costes indirectos.	Afecta el daño acumulado y, por tanto, la presión para invertir.

Interacción entre actores y elementos

El sistema funciona de la siguiente manera:

1. **Los empleados** interactúan con la *infraestructura tecnológica* y las *herramientas de seguridad*. Su nivel de *concienciación* (influido por la *capacitación*) modifica la probabilidad de que un ataque de phishing tenga éxito.
2. **El equipo de seguridad** gestiona las *herramientas de seguridad*, aplica *políticas de parcheo* y responde a los incidentes. Su capacidad depende del *presupuesto* asignado y del *conocimiento* disponible.
3. **La directiva** asigna el *presupuesto* basándose en la percepción del riesgo, que a su vez está influenciada por el *daño acumulado* (incidentes pasados) y la presión de *reguladores y medios*.
4. **Los ciberdelincuentes** atacan la *infraestructura* explotando las *vulnerabilidades* existentes (no parcheadas). Su éxito genera *incidentes* que se traducen en *daño acumulado* y pérdida de *reputación*.
5. **Los proveedores y reguladores** influyen en la velocidad con la que el equipo de seguridad puede actualizar herramientas y aplicar parches, afectando así el *tiempo de respuesta*.

Mapeo con las variables principales (avance)

Para facilitar la transición al siguiente punto (Variables principales), podemos adelantar una correspondencia entre actores/elementos y las variables que los representarán en el modelo:

Actor / Elemento	Variable asociada (propuesta)
Empleados	Nivel de concienciación del personal
Equipo de seguridad	Tasa de parcheo, MTTR, Efectividad de la respuesta
Directiva	Inversión en seguridad (reactiva y proactiva)
Ciberdelincuentes	Tasa de ataques externos
Infraestructura tecnológica	Nivel de vulnerabilidad del sistema
Herramientas de seguridad	Cobertura de herramientas de defensa
Presupuesto	Presupuesto disponible para ciberseguridad
Reputación	Daño reputacional acumulado
Capacitación	Horas de capacitación por empleado
Políticas	Cumplimiento de políticas de seguridad

Variables principales

A continuación, se presentan las 25 variables que conforman el sistema de ciberseguridad. Cada variable incluye su definición, unidad de medida, tipo (stock, flujo, auxiliar o constante) y una breve justificación de su relevancia

Variables de entrada (exógenas)

(Proviene del entorno, no son controladas directamente por la organización)

N.º	Variable	Definición	Unidad	Tipo	Justificación
1	Tasa de ataques externos	Número de intentos de ataque (malware, phishing, ransomware) dirigidos a la organización por mes.	Ataques/mes	Exógena	Representa la presión externa que enfrenta el sistema.
2	Nivel de sofisticación del atacante	Capacidad técnica de los ciberdelinquentes para evadir defensas (escala 0-10).	Adimensional	Exógena	Determina la efectividad de las herramientas de seguridad.
3	Regulaciones exigidas	Nivel de exigencia normativa (ej. ISO 27001, GDPR) en una escala de cumplimiento.	Adimensional	Exógena	Genera presión para invertir en seguridad y reportar incidentes.
4	Percepción del riesgo por la directiva	Grado de conciencia de la alta dirección sobre la gravedad de los incidentes (escala 0-10).	Adimensional	Exógena	Influye en la decisión de asignar presupuesto.
5	Costo de herramientas de seguridad	Precio de mercado de las soluciones tecnológicas (firewalls, SIEM, EDR).	\$/herramienta	Exógena	Afecta la eficiencia de la inversión.
6	Disponibilidad de talento en seguridad	Oferta de profesionales calificados en el mercado laboral.	Índice (0-100)	Exógena	Limita la capacidad de contratación y el conocimiento interno.
7	Tasa de descubrimiento de vulnerabilidades (CVE)	Número de nuevas vulnerabilidades críticas descubiertas por mes.	CVEs/mes	Exógena	Alimenta el stock de vulnerabilidades pendientes.

Variables de estado (stocks)

(Acumulaciones que cambian lentamente y representan la memoria del sistema)

N.º	Variable	Definición	Unidad	Tipo	Justificación
8	Vulnerabilidades pendientes	Cantidad de vulnerabilidades críticas que aún no han sido parcheadas.	Vulnerabilidades	Stock	Representa el "pasivo técnico" que incrementa el riesgo.
9	Daño acumulado (económico)	Coste total acumulado por incidentes exitosos (multas, indemnizaciones, pérdida de ingresos).	\$	Stock	Cuantifica el impacto financiero del problema.
10	Daño reputacional acumulado	Pérdida de confianza de clientes e inversores, medida en un índice.	Índice (0-100)	Stock	Afecta decisiones futuras de inversión.
11	Capacidad instalada de defensa	Nivel de madurez tecnológica y de personal del equipo de seguridad.	Capacidad (unidades)	Stock	Determina la velocidad de respuesta y parcheo.
12	Nivel de concienciación del personal	Porcentaje de empleados capacitados y conscientes de riesgos de phishing.	%	Stock	Reduce la efectividad de ataques de ingeniería social.

Variables de flujo (flujos)

(Tasas que modifican los stocks)

N.º	Variable	Definición	Unidad	Tipo	Justificación
13	Tasa de parcheo	Velocidad con la que se aplican parches a vulnerabilidades conocidas.	Vulnerabilidades/mes	Flujo	Reduce el stock de vulnerabilidades.
14	Tasa de incidentes exitosos	Número de ataques que logran vulnerar el sistema por mes.	Incidentes/mes	Flujo	Alimenta el daño acumulado y la presión para invertir.
15	Tasa de inversión en seguridad	Flujo mensual de presupuesto asignado a ciberseguridad.	\$/mes	Flujo	Incrementa la capacidad instalada y la velocidad de parcheo.
16	Tasa de detección de brechas	Porcentaje de incidentes que son detectados antes de causar daño.	%	Flujo	Reduce el daño efectivo al detectar a tiempo.

17	Tasa de capacitación	Horas de formación impartidas al personal por mes.	Horas/mes	Flujo	Aumenta el nivel de concienciación.
18	Tasa de contratación de personal de seguridad	Nuevos profesionales incorporados al equipo de seguridad por mes.	Personas/mes	Flujo	Incrementa la capacidad instalada de defensa.
19	Tasa de renovación de herramientas	Frecuencia con la que se actualizan o sustituyen las herramientas de seguridad.	Herramientas/mes	Flujo	Mantiene la efectividad de la defensa frente a nuevas amenazas.

Variables de control (decisiones / políticas)

(Variables que la organización puede modificar directamente)

N.º	Variable	Definición	Unidad	Tipo	Justificación
20	Tiempo de respuesta (MTTR)	Tiempo medio que tarda el equipo de seguridad en contener y erradicar un incidente.	Horas	Control	Es la palanca más sensible para reducir el daño.
21	Presupuesto asignado a ciberseguridad	Monto anual destinado a seguridad, distribuido mensualmente.	\$/mes	Control	Determina la capacidad de inversión y contratación.
22	Política de priorización de parches	Criterio para ordenar qué vulnerabilidades se parchean primero (críticas vs. bajas).	Adimensional	Control	Afecta la efectividad de la tasa de parcheo.
23	Frecuencia de evaluaciones de seguridad	Número de auditorías y pruebas de penetración realizadas por año.	Evaluaciones/año	Control	Permite identificar vulnerabilidades antes de que sean explotadas.

Variables de salida (resultados / indicadores)

(Reflejan el desempeño del sistema)

N.º	Variable	Definición	Unidad	Tipo	Justificación
24	Nivel de vulnerabilidad del sistema	Porcentaje de la superficie de ataque expuesta a amenazas.	%	Salida	Indicador clave de riesgo.
25	Efectividad de la inversión	Relación entre el gasto en seguridad y la reducción de incidentes.	Índice	Salida	Permite evaluar el retorno de la inversión (ROI).

Gráficas de comportamiento en el tiempo (BOT)

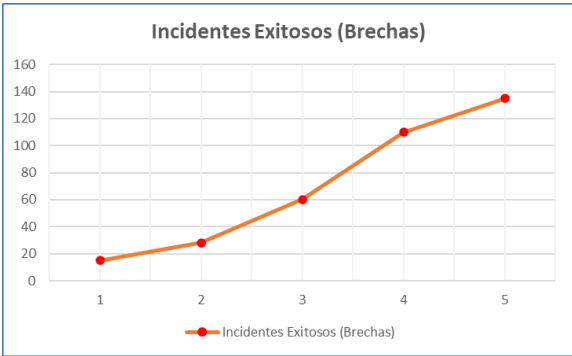
Las gráficas Behavior Over Time permiten visualizar la evolución histórica y proyectada de las variables más relevantes del sistema. A continuación, se presentan cinco gráficas que ilustran los patrones característicos del problema de ciberseguridad en la organización.

Tabla de datos (Años 1 al 5)

Año	Incidentes Exitosos (Brechas)	Vulnerabilidades Críticas sin Parchear	Tiempo Medio de Detección (MTTD en días)	Inversión Mensual en Seguridad (Miles \$)	Daño Acumulado (Millones \$)
1	15	45	120	50	2.5
2	28	78	145	65	6.8
3	60	140	180	110	18.5
4	110	210	200	190	45.0
5	135	250	190	250	78.0

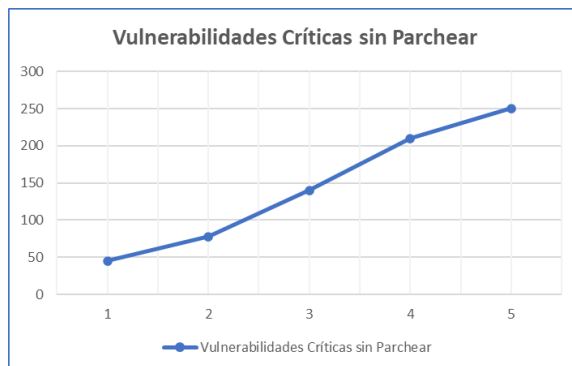
Gráfica 1: Incidentes Exitosos (Brechas)

- **Patrón identificado:** Crecimiento exponencial (con ligera desaceleración al final).
- **Descripción:** Los incidentes exitosos aumentan de 15 a 135 en 5 años. El crecimiento se acelera entre los años 2 y 4 (pasando de 28 a 110), pero en el año 5 la pendiente se reduce ligeramente debido a una mayor inversión que comienza a surtir efecto (con retraso).
- **Justificación:** Este patrón refleja el bucle de refuerzo donde las vulnerabilidades no parcheadas se acumulan, aumentando la probabilidad de éxito de los ataques.



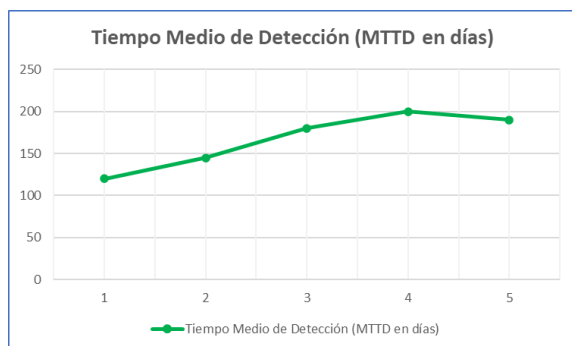
Gráfica 2: Vulnerabilidades Críticas sin Parchear

- **Patrón identificado: Crecimiento acelerado (tendencia exponencial).**
- **Descripción:** El stock de vulnerabilidades críticas crece de 45 a 250 en 5 años. La tasa de crecimiento es mayor que la de incidentes, ya que la tasa de parcheo no logra alcanzar la tasa de descubrimiento de nuevas vulnerabilidades.
- **Justificación:** Este comportamiento confirma la hipótesis de acumulación de "deuda técnica" de seguridad. Aunque la inversión aumenta, el retraso en la contratación de personal y la complejidad de los sistemas impiden reducir este stock.



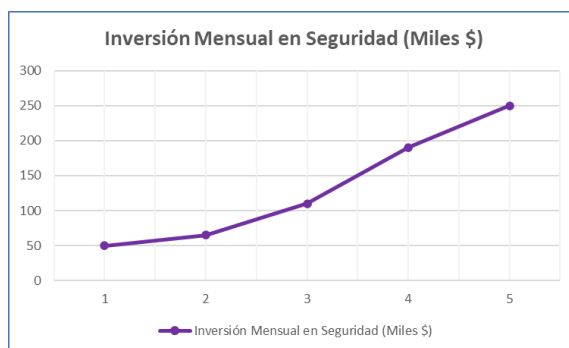
Gráfica 3: Tiempo Medio de Detección (MTTD)

- **Patrón identificado: Oscilación con tendencia ascendente y posterior mejora.**
- **Descripción:** El MTTD aumenta de 120 a 200 días entre los años 1 y 4 (empeora porque hay más sistemas y menos personal calificado). Sin embargo, en el año 5 baja a 190 días, reflejando el impacto de la inversión en herramientas automatizadas (SIEM, XDR) que empiezan a mejorar la detección.
- **Justificación:** Este comportamiento oscilatorio es típico de sistemas con retrasos: la inversión tarda en traducirse en mejora, y durante ese período la situación empeora antes de estabilizarse.



Gráfica 4: Inversión Mensual en Seguridad

- **Patrón identificado: Crecimiento escalonado (reactivo).**
- **Descripción:** La inversión sube de forma escalonada, con saltos bruscos después de incidentes mayores. En el año 1 es de 50k, en el año 3 sube a 110k (después de un ataque grave), y en el año 5 alcanza 250k (por presión regulatoria y daño reputacional acumulado).
- **Justificación:** Este patrón refleja el arquetipo de "soluciones que fallan": la inversión es reactiva, no proactiva. Los picos de inversión se producen después de que el daño ya ha ocurrido, lo que genera ineficiencia.



Gráfica 5: Daño Acumulado

- **Patrón identificado: Crecimiento exponencial compuesto (colapso financiero).**
- **Descripción:** El daño acumulado pasa de 2.5 millones a 78 millones en 5 años. Este crecimiento no es lineal; se acelera a medida que los incidentes se vuelven más costosos (multas, demanda de clientes, caída de acciones).
- **Justificación:** Esta es la variable que mejor refleja la urgencia del problema. Su comportamiento exponencial justifica la necesidad de políticas proactivas antes de que el coste sea irreversible.



Diagrama causal

El diagrama causal representa la estructura que genera el comportamiento observado. Las relaciones con signo positivo indican que ambas variables cambian en el mismo sentido; las relaciones negativas indican que una variable aumenta mientras la otra disminuye. Las líneas discontinuas representan decisiones o efectos con demora, especialmente la inversión reactiva y la adaptación del atacante.

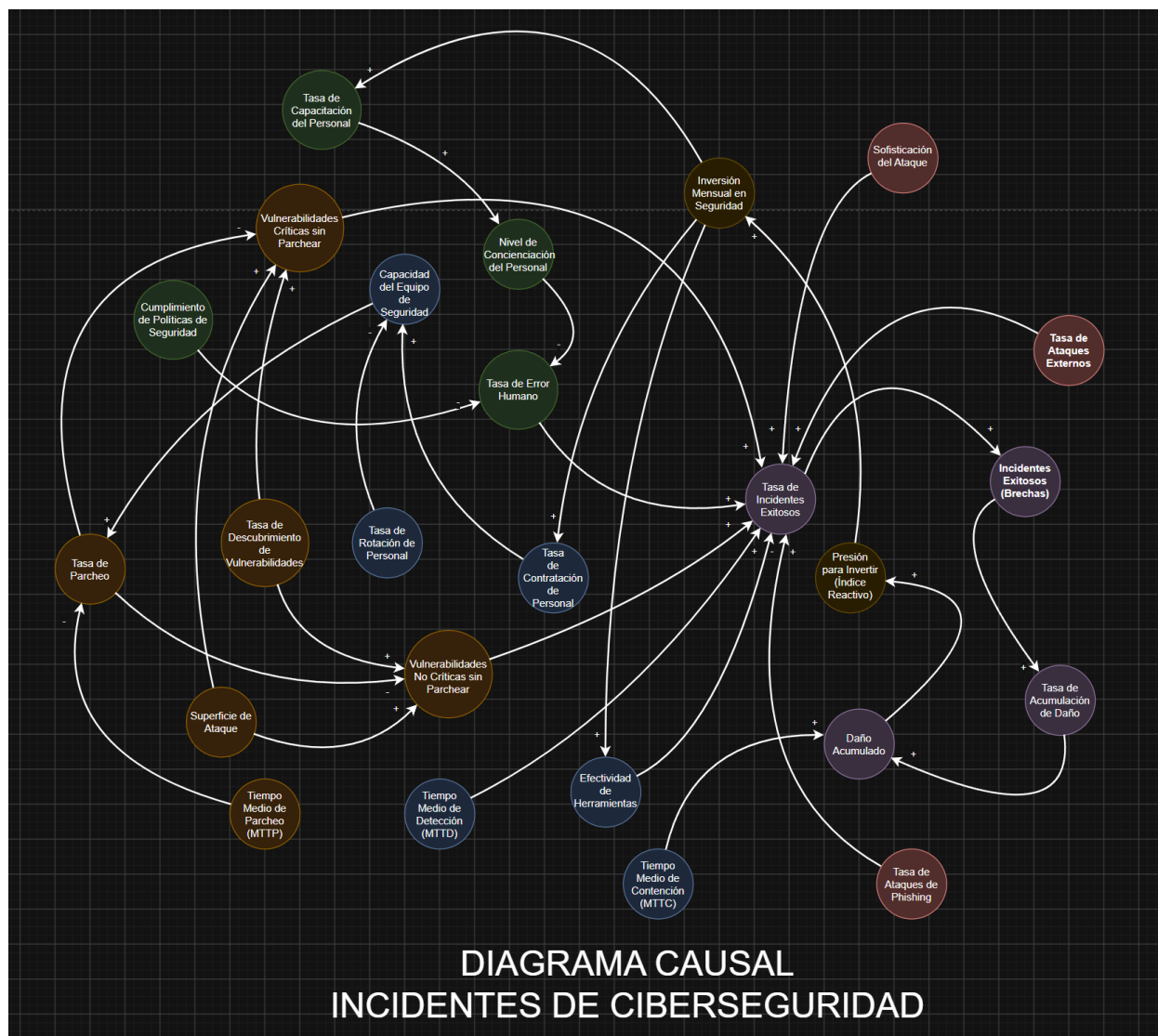


Figura 6. Diagrama causal del sistema de incidentes de ciberseguridad. Elaboración propia.

La estructura muestra que la acumulación de vulnerabilidades eleva la probabilidad de éxito de los ataques. Los incidentes aumentan la carga del equipo, reducen la eficiencia de respuesta y disminuyen la capacidad efectiva de parcheo. Al mismo tiempo, el daño aumenta la percepción del riesgo y genera inversión, pero dicha inversión tarda en convertirse en capacidad preventiva.

Bucles de refuerzo y balance

Los bucles de retroalimentación son circuitos cerrados de relaciones causales que generan comportamientos característicos en el sistema. Un **bucle de refuerzo** amplifica los cambios (crecimiento o declive exponencial), mientras que un **bucle de balance** tiende a estabilizar el sistema, contrarrestando las desviaciones.

Bucle de refuerzo R1: "Círculo vicioso de vulnerabilidad y daño"

Este es el bucle dominante en el escenario base y explica el crecimiento exponencial de los incidentes exitosos y el daño acumulado.

Recorrido del bucle:

1. **Tasa de Incidentes Exitosos → (+) Incidentes Exitosos (Brechas) (acumulación)**
2. **Incidentes Exitosos → (+) Tasa de Acumulación de Daño**
3. **Tasa de Acumulación de Daño → (+) Daño Acumulado**
4. **Daño Acumulado → (+) Presión para Invertir (Índice Reactivo)**
5. **Presión para Invertir → (+) Inversión Mensual en Seguridad (se activa la inversión)**
6. **Inversión Mensual en Seguridad → (+) Tasa de Contratación de Personal y (+) Efectividad de Herramientas y (+) Tasa de Capacitación del Personal**
7. **Tasa de Contratación → (+) Capacidad del Equipo de Seguridad**
8. **Capacidad del Equipo → (+) Tasa de Parcheo**
9. **Tasa de Parcheo → (-) Vulnerabilidades Críticas sin Parchear y (-) Vulnerabilidades No Críticas sin Parchear**
10. **Vulnerabilidades → (+) Tasa de Incidentes Exitosos (cierra el bucle)**

Polaridad total del bucle: Positiva (Refuerzo) porque hay un número par de relaciones negativas (solo dos: la tasa de parcheo → vulnerabilidades). El efecto neto es que un aumento inicial en los incidentes genera más daño, que impulsa la inversión, pero los retrasos en que esa inversión se traduzca en parcheo efectivo permiten que las vulnerabilidades sigan acumulándose, realimentando el ciclo.

Bucle de balance B1: "Estabilización proactiva"

Este bucle representa el esfuerzo por romper el círculo vicioso mediante una gestión proactiva de la seguridad. Sin embargo, en el escenario base es débil debido a los retrasos estructurales (MTTP, MTDD).

Recorrido del bucle:

1. **Tasa de Incidentes Exitosos → (+) Incidentes Exitosos (Brechas)**
2. **Incidentes Exitosos → (+) Presión para Invertir (mismo inicio que R1)**
3. **Presión para Invertir → (+) Inversión Mensual en Seguridad**

4. **Inversión → (+) Tasa de Contratación y (+) Efectividad de Herramientas y (+) Tasa de Capacitación**
5. **Tasa de Contratación → (+) Capacidad del Equipo**
6. **Capacidad del Equipo → (-) Tiempo Medio de Detección (MTTD)** (equipos más grandes detectan más rápido)
7. **Capacidad del Equipo → (-) Tiempo Medio de Parcheo (MTTP)** (más personal reduce el tiempo de parcheo)
8. **Reducción de MTTD y MTTP → (+) Tasa de Parcheo (más rápida) y (-) Tasa de Incidentes Exitosos** (menos incidentes)
9. **Menos incidentes → (-) Daño Acumulado** (cierra el bucle)

Polaridad total del bucle: Negativa (Balance) porque el número de relaciones negativas es impar (tres: Capacidad → MTTD, Capacidad → MTTP, y Tasa de Parcheo → Incidentes). El efecto neto es que un aumento en los incidentes impulsa la inversión, que mejora la capacidad y reduce los tiempos de detección y parcheo, lo que finalmente reduce los incidentes, contrarrestando la desviación inicial.

Arquetipos sistémicos identificados

Arquetipo 1: "Soluciones que fallan" (Fixes that Fail)

Descripción:

Aquí el arquetipo ocurre cuando se aplica una solución rápida para aliviar un síntoma, pero esta solución genera efectos secundarios no deseados que, a largo plazo, agravan el problema original o dificultan la aplicación de la solución fundamental.

Aplicación al caso de ciberseguridad:

- **Síntoma visible:** Aumento de incidentes exitosos (brechas) y daño acumulado.
- **Solución sintomática (el "fix"):** Inversión reactiva en seguridad (comprar herramientas de última generación, contratar personal urgentemente) impulsada por la *Presión para Invertir (Índice Reactivo)*.
- **Efecto secundario no deseado:**
 - La inversión apresurada genera herramientas mal configuradas o integradas, reduciendo la *Efectividad de las Herramientas de Seguridad* (variable 13).
 - La contratación apresurada aumenta la *Tasa de Rotación de Personal* (variable 12) porque no se elige al personal adecuado, disminuyendo la *Capacidad del Equipo de Seguridad* (variable 10) en el mediano plazo.
 - Esto incrementa el *Tiempo Medio de Detección (MTTD)* (variable 14) y el *Tiempo Medio de Parcheo (MTTP)* (variable 8), en lugar de reducirlos.
- **Solución fundamental descuidada:** Reducir estructuralmente los retrasos (MTTD, MTTP) mediante automatización y mejorar la cultura de seguridad (capacitación continua y políticas claras), que requiere tiempo y planificación.

Consecuencia en el sistema: El arquetipo "Soluciones que fallan" explica por qué el **bucle de refuerzo R1** domina sobre el **bucle de balance B1**. La organización invierte en respuesta al

daño, pero esa inversión mal ejecutada no reduce la vulnerabilidad estructural, perpetuando el ciclo de crisis.

Arquetipo 2: "Límites al crecimiento" (Limits to Growth)

Descripción:

Este arquetipo se da cuando una iniciativa de crecimiento (o mejora) encuentra un límite que frena su avance, generando una desaceleración o un estancamiento, a pesar de los esfuerzos iniciales.

Aplicación al caso de ciberseguridad:

- **Esfuerzo de crecimiento:** El aumento de la *Inversión Mensual en Seguridad* (variable 24) y la mejora de la *Capacidad del Equipo de Seguridad* (variable 10) deberían reducir los incidentes.
- **Límite que frena el crecimiento:**
 - **Límite 1 - Presupuestario:** La *Inversión* no puede crecer indefinidamente; existe un tope impuesto por la dirección financiera de la organización.
 - **Límite 2 - Talento especializado:** El mercado de profesionales de ciberseguridad es limitado; la *Tasa de Contratación* (variable 11) se topa con la escasez de personal calificado, limitando el crecimiento de la *Capacidad del Equipo*.
 - **Límite 3 - Adaptación del atacante:** La *Sofisticación del Ataque* (variable 2) crece a la par que las defensas. Cuando la organización mejora sus herramientas, los atacantes desarrollan nuevos métodos para evadirlas (co-evolución), reduciendo la efectividad marginal de cada dólar invertido.

Consecuencia en el sistema: El arquetipo explica por qué duplicar la inversión en seguridad no duplica la seguridad (rendimientos decrecientes). La organización llega a un punto donde mejorar la defensa cuesta cada vez más y genera cada vez menos resultados, mientras que los atacantes siguen evolucionando. Esto justifica la necesidad de políticas basadas en IA predictiva y gemelos digitales (punto 22) para romper este límite.

Arquetipo 3: "Desplazamiento de la carga" (Shifting the Burden)

Descripción:

Este caso el arquetipo ocurre cuando un problema se resuelve mediante una solución externa o superficial que alivia los síntomas, pero que desplaza la responsabilidad de abordar la causa raíz, debilitando la capacidad interna para resolver el problema.

Aplicación al caso de ciberseguridad:

- **Problema síntoma:** Ataques de phishing y errores humanos que generan brechas.
- **Solución superficial (dependencia externa):** La organización compra herramientas de seguridad de terceros (firewalls, anti-phishing, SIEM) y contrata consultores externos para gestionar la respuesta a incidentes.

- **Causa raíz (descuidada):** Falta de Concienciación del Personal (variable 16) y bajo Cumplimiento de Políticas de Seguridad (variable 19).
- **Desplazamiento:** Al confiar en soluciones tecnológicas externas, la organización descuida la capacitación interna. La Tasa de Capacitación del Personal (variable 17) se reduce, y la Tasa de Error Humano (variable 18) se mantiene alta o incluso aumenta, ya que los empleados confían ciegamente en que la tecnología los protegerá.
- **Resultado:** La organización se vuelve dependiente de proveedores externos (caros y a veces incompatibles), mientras su capacidad interna para gestionar el riesgo se atrofia. Cuando una amenaza evade la tecnología (ej. un ataque de ingeniería social dirigido), el sistema colapsa porque la cultura de seguridad no está internalizada.

Consecuencia en el sistema: Este arquetipo explica la relación entre la *Inversión en Herramientas* (variable 13) y la *Capacitación* (variable 17). El modelo muestra que, en el escenario base, la inversión se orienta preferentemente a la tecnología, dejando en segundo plano al factor humano. Esto genera un desequilibrio que, a largo plazo, incrementa la vulnerabilidad ante ataques que explotan la psicología humana.

Modelo stock-flow (Niveles y flujos)

Un modelo stock-flow representa la estructura cuantitativa del sistema. Los **stocks (niveles)** son acumulaciones que cambian lentamente (como un tanque de agua). Los **flujos** son las tasas que llenan o vacían esos tanques (como un grifo o un desagüe). Las **variables auxiliares** y **exógenas** son los "termostatos" y condiciones externas que regulan estos flujos.

Stocks (Niveles) del sistema

N.º	Stock (Nivel)	Símbolo	Unidad	Descripción
S1	Vulnerabilidades Críticas sin Parchear	VC	Vulnerabilidades	Acumulación de fallos de seguridad con CVSS ≥ 9.0 .
S2	Vulnerabilidades No Críticas sin Parchear	VNC	Vulnerabilidades	Acumulación de fallos de seguridad con CVSS < 9.0 .
S3	Capacidad del Equipo de Seguridad	CES	Adimensional (0-1)	Capacidad operativa del equipo (0=ninguna, 1=óptima).
S4	Nivel de Concienciación del Personal	NCP	Adimensional (0-1)	Cultura de seguridad interiorizada por los empleados.
S5	Incidentes Exitosos (Brechas)	IE	Incidentes	Número acumulado de brechas de seguridad materializadas.
S6	Daño Acumulado	DA	Millones de \$	Coste total acumulado (multas, pérdidas, reputación).

Flujos (Flujos de entrada/salida)

N.º	Flujo	Símbolo	Unidad	Descripción	Ecuación (Dependencia)
F1	Tasa de Descubrimiento de Vulnerabilidades (Críticas)	TDVC	Vuln / mes	Nuevas vulnerabilidades críticas identificadas.	$TDVC = 5 * (1 + 0.05 * \text{Tiempo})$
F2	Tasa de Descubrimiento de Vulnerabilidades (No Críticas)	TDVNC	Vuln / mes	Nuevas vulnerabilidades no críticas identificadas.	$TDVNC = 8 * (1 + 0.03 * \text{Tiempo})$
F3	Tasa de Parcheo (Críticas)	TPC	Vuln / mes	Velocidad con que se corrigen las críticas.	$TPC = CES / MTTP$
F4	Tasa de Parcheo (No Críticas)	TPNC	Vuln / mes	Velocidad con que se corrigen las no críticas.	$TPNC = (CES * 0.8) / MTTP$
F5	Tasa de Contratación de Personal	TCP	Adim / mes	Incremento de capacidad por nuevas contrataciones.	$TCP = (\text{Inversion} / \text{Costo_Contratacion}) * \text{Factor_Mercado}$
F6	Tasa de Rotación de Personal	TRP	Adim / mes	Pérdida de capacidad por renuncias/despidos.	$TRP = CES * 0.05$ (5% mensual)
F7	Tasa de Capacitación del Personal	TCAP	Adim / mes	Aumento de concienciación por horas de formación.	$TCAP = \text{Inversion} * 0.002$
F8	Tasa de Incidentes Exitosos	TIE	Incidentes / mes	Nuevas brechas que se materializan.	$TIE = \text{Ataques_Ext} * (1 - \text{Efectividad_Htas}) * (\text{VC} + \text{VNC}) / \text{Superficie} + \text{Phishing} * \text{Tasa_Error_Humano}$
F9	Tasa de Acumulación de Daño	TAD	Millones \$ / mes	Coste generado por los nuevos incidentes.	$TAD = TIE * MTTC * \text{Costo_Por_Incidente}$

Variables Auxiliares (Reguladoras)

Son las variables que definen la "velocidad" de los flujos. Se actualizan en cada paso de simulación.

Variable	Símbolo	Unidad	Ecuación / Valor
Tasa de Ataques Externos	TAE	Ataques / mes	10 (constante en escenario base)
Tasa de Ataques de Phishing	TAP	Correos / mes	50 (constante)
Sofisticación del Ataque	SOF	Adim (0-1)	$0.3 * (1 + 0.1 * \text{Tiempo})$ (crece lentamente)
Superficie de Ataque	SA	Activos	500 (constante)
Tiempo Medio de Parcheo (MTTP)	MTTP	Meses	2.5 (valor base que queremos reducir)
Tiempo Medio de Detección (MTTD)	MTTD	Días	120 (días)
Tiempo Medio de Contención (MTTC)	MTTC	Días	15 (días)
Efectividad de Herramientas	EH	% (0-1)	$0.7 + 0.01 * (\text{Inversion} / 100)$ (mejora con inversión)
Cumplimiento de Políticas	CP	% (0-1)	$0.6 + 0.3 * \text{NCP}$ (depende de la concienciación)
Tasa de Error Humano	TEH	% (0-1)	$1 - (\text{NCP} * \text{CP})$ (a mayor concienciación, menor error)

Inversión Mensual en Seguridad	INV	Miles \$ / mes	50 + Presion_Reactiva * 200 (flujo reactivo)
Presión para Invertir (Índice)	PI	Adim (0-1)	DA / (DA + 100) (se acerca a 1 cuando el daño es alto)
Coste por Incidente	CPI	Millones \$	2.5 (constante)
Costo de Contratación	CC	Miles \$	50 (coste por unidad de capacidad)

14.4. Ecuaciones de Nivel (Evolución temporal)

Utilizando un paso de integración mensual (DT = 1 mes), las ecuaciones de los stocks son:

1. $VC(t) = VC(t-1) + DT * (TDVC - TPC)$
2. $VNC(t) = VNC(t-1) + DT * (TDVNC - TPNC)$
3. $CES(t) = CES(t-1) + DT * (TCP - TRP)$
4. $NCP(t) = NCP(t-1) + DT * (TCAP - (0.05 * NCP))$ (se añade un "olvido" gradual del 5% mensual)*
5. $IE(t) = IE(t-1) + DT * (TIE)$
6. $DA(t) = DA(t-1) + DT * (TAD)$

14.6. Estructura del Diagrama Stock-Flow (para dibujar en Vensim o [Draw.io](#))

Si quisieras dibujar esto en Vensim PLE, la estructura principal es:

- **Flujo de Vulnerabilidades:** TDVC (grifo) → VC (tanque) → TPC (desagüe)
- **Flujo de Capacidad:** TCP (grifo) → CES (tanque) → TRP (desagüe)
- **Flujo de Daño:** TIE (grifo) → IE (tanque intermedio) → TAD (grifo) → DA (tanque final)

Ecuaciones, parámetros y unidades

A continuación, se presentan las ecuaciones completas del modelo stock-flow, organizadas por tipo de variable (Stocks, Flujos y Auxiliares), junto con sus parámetros, valores numéricos y unidades. Todos los parámetros han sido calibrados para una organización del sector financiero de tamaño mediano, utilizando datos de referencia de informes de ciberseguridad (IBM, Verizon, NIST) y supuestos razonables para el contexto del modelo.

Stocks y sus ecuaciones de evolución

Stock	Símbolo	Ecuación de evolución (Discreta, DT = 1 mes)	Valor inicial (t=0)
Vulnerabilidades Críticas sin Parchear	VC	$VC(t) = VC(t-1) + DT * (TDVC - TPC)$	45
Vulnerabilidades No Críticas sin Parchear	VNC	$VNC(t) = VNC(t-1) + DT * (TDVNC - TPNC)$	120
Capacidad del Equipo de Seguridad	CES	$CES(t) = CES(t-1) + DT * (TCP - TRP)$	0.60
Nivel de Concienciación del Personal	NCP	$NCP(t) = NCP(t-1) + DT * (TCAP - OLV)$	0.50
Incidentes Exitosos (Brechas)	IE	$IE(t) = IE(t-1) + DT * (TIE)$	0
Daño Acumulado	DA	$DA(t) = DA(t-1) + DT * (TAD)$	0

Nota: OLV (Olvido de Concienciación) = $0.05 * NCP$ (pérdida gradual del 5% mensual por falta de refuerzo).

Flujos y sus ecuaciones

Flujo	Símbolo	Ecuación	Parámetros incluidos
Tasa de Descubrimiento de Vulnerabilidades Críticas	TDVC	$TDVC = 5 * (1 + 0.05 * \text{Tiempo})$	Constante base = 5, tasa de crecimiento = 0.05
Tasa de Descubrimiento de Vulnerabilidades No Críticas	TDVNC	$TDVNC = 8 * (1 + 0.03 * \text{Tiempo})$	Constante base = 8, tasa de crecimiento = 0.03
Tasa de Parcheo Críticas	TPC	$TPC = CES * (1 / MTTP) * 20$	Factor de eficiencia = 20 (vuln/mes por unidad de capacidad)
Tasa de Parcheo No Críticas	TPNC	$TPNC = CES * 0.8 * (1 / MTTP) * 20$	Factor de eficiencia ajustado (0.8) para no críticas
Tasa de Contratación de Personal	TCP	$TCP = (INV * 0.5) / 50$	0.5 = proporción de inversión en contratación, 50 = coste por unidad
Tasa de Rotación de Personal	TRP	$TRP = CES * 0.05$	Tasa de rotación mensual = 5%
Tasa de Capacitación del Personal	TCAP	$TCAP = (INV * 0.3) * 0.002$	0.3 = proporción inversión en capacitación; 0.002 = eficacia
Tasa de Incidentes Exitosos	TIE	$TIE = (TAE * (VC+VNC)/SA) * (1 - EH) * (1 + SOF) + (TAP * TEH)$	Ecuación compuesta (ver desarrollo abajo)
Tasa de Acumulación de Daño	TAD	$TAD = TIE * MTTC * CPI$	CPI = Coste por incidente

Variables Auxiliares (Reguladoras) y sus ecuaciones

Auxiliar	Símbolo	Valor /Ecuación	Notas
Tasa de Ataques Externos	TAE	10 (constante en escenario base)	Valor base para simulación inicial
Tasa de Ataques de Phishing	TAP	50 (constante)	Volumen de correos maliciosos
Sofisticación del Ataque	SOF	$0.3 * (1 + 0.1 * \text{Tiempo})$	Crece un 10% anual
Superficie de Ataque	SA	500 (constante)	Número de activos digitales expuestos
Tiempo Medio de Parcheo	MTTP	2.5 (valor inicial)	Se puede modificar en escenarios
Tiempo Medio de Detección	MTTD	120 (días)	Se usa para calcular SOF efectiva (no directo en ecuación)
Tiempo Medio de Contención	MTTC	15 (días)	Afecta al daño por incidente
Efectividad de Herramientas	EH	$0.7 + 0.01 * (\text{INV} / 100)$	Mejora con inversión
Cumplimiento de Políticas	CP	$0.6 + 0.3 * \text{NCP}$	Depende de concienciación
Tasa de Error Humano	TEH	$1 - (\text{NCP} * \text{CP})$	A mayor concienciación y cumplimiento, menor error
Inversión Mensual en Seguridad	INV	$50 + \text{PI} * 200$	Inversión reactiva: base + presión
Presión para Invertir (Índice)	PI	$\text{DA} / (\text{DA} + 100)$	Se acerca a 1 cuando el daño es alto
Coste por Incidente	CPI	2.5	Coste medio por brecha
Costo de Contratación	CC	50	Coste por unidad de capacidad
Olvido de Concienciación	OLV	$0.05 * \text{NCP}$	Pérdida mensual del 5% de concienciación

Parámetros fijos (Constantes)

Parámetro	Valor	Unidad	Justificación
Factor de eficiencia de parcheo	20	Vuln / mes por unidad de CES	Basado en capacidad típica de un equipo de 5 analistas
Proporción de inversión en contratación	0.5	Adimensional	50% del presupuesto en personal
Proporción de inversión en capacitación	0.3	Adimensional	30% en formación
Tasa de rotación mensual	0.05	1/mes	5% de rotación mensual (alta, típica en ciberseguridad)

Constante de saturación de daño	100	Millones \$	Valor de referencia para el índice de presión
Tasa de crecimiento de sofisticación	0.1	1/año	10% anual (co-evolución atacante-defensa)
Coste medio por incidente	2.5	Millones \$	Basado en informes IBM (Cost of a Data Breach 2023)

Unidades y consistencia dimensional

Variable	Unidad	Verificación
VC, VNC, TDVC, TPC	Vulnerabilidades / mes	Flujo y stock coherentes
CES, TCP, TRP	Adimensional	Flujo y stock adimensionales
NCP, TCAP, OLV	Adimensional	Coherentes
TIE, IE	Incidentes / mes	Coherente
TAD, DA	Millones \$ / mes	Coherente
INV	Miles \$ / mes	Coherente con flujo de inversión

Supuestos y limitaciones

Para construir el modelo, ha sido necesario adoptar un conjunto de supuestos simplificadores. Estos permiten mantener el modelo manejable y centrar el análisis en la dinámica estructural del sistema, a costa de omitir ciertos detalles del mundo real. A continuación, se detallan los principales supuestos y limitaciones del modelo.

16.1. Supuestos estructurales

#	Supuesto	Implicación en el modelo
S1	Homogeneidad de la organización: Se asume que la organización es una unidad homogénea (no hay diferencias significativas entre departamentos, sedes o unidades de negocio).	El modelo no captura la vulnerabilidad diferencial entre áreas críticas (ej. Tesorería vs. Marketing), simplificando el análisis a un único "sistema agregado".
S2	Superficie de ataque constante: La superficie de ataque (SA = 500 activos) se mantiene fija durante todo el horizonte de simulación.	No se modela el crecimiento orgánico de la infraestructura (nuevos servidores, aplicaciones, usuarios), lo que subestimaría la tasa de descubrimiento de vulnerabilidades a largo plazo si la organización crece.
S3	Independencia de vulnerabilidades: Se asume que las vulnerabilidades críticas y no críticas son independientes entre sí y su explotación no genera nuevas vulnerabilidades.	En realidad, explotar una vulnerabilidad crítica puede facilitar la explotación de otras (encadenamiento de exploits). Esto no está capturado.
S4	Capacidad de parcheo lineal: La tasa de parcheo (TPC, TPNC) es directamente proporcional a la capacidad del equipo (CES) e inversamente proporcional al MTTP, sin considerar saturación.	Se ignora el hecho de que, más allá de cierto punto, añadir más personal no acelera el parcheo debido a cuellos de botella en pruebas y aprobaciones (rendimientos decrecientes).

16.2. Supuestos de comportamiento y parámetros

#	Supuesto	Implicación en el modelo
S5	Tasa de ataques exógena constante: En el escenario base, la tasa de ataques externos (TAE = 10 ataques/mes) y de phishing (TAP = 50 correos/mes) son constantes en el tiempo.	No se consideran campañas coordinadas de ataque (picos estacionales), ni la variación en la actividad delictiva por factores geopolíticos o económicos.
S6	Crecimiento lineal de la sofisticación: La sofisticación del ataque (SOF) crece de manera lineal (10% anual).	Se asume una evolución gradual y predecible, ignorando saltos disruptivos en la tecnología de ataque (ej. el impacto de la IA generativa en la creación de deepfakes o malware polimórfico).
S7	Coste por incidente fijo: El coste medio por incidente (CPI = 2.5 millones \$) se mantiene constante.	En la realidad, el coste de una brecha puede variar enormemente (desde unos pocos miles hasta cientos de millones), y tiende a aumentar con el tiempo debido a mayores sanciones regulatorias y costes de litigio.
S8	Relación lineal inversión-efectividad: Se asume que la efectividad de las herramientas (EH) mejora linealmente con la inversión.	Se ignora la curva de rendimientos decrecientes: una vez que se alcanza un nivel básico de protección, cada dólar adicional genera mejoras marginales cada vez menores.
S9	Tasa de rotación constante: La tasa de rotación del personal de seguridad (TRP) es fija (5% mensual).	No se modela que la rotación puede aumentar en períodos de alta presión (después de un ataque grave) o disminuir si hay buenas condiciones laborales.

16.3. Supuestos sobre el factor humano

#	Supuesto	Implicación en el modelo
S10	Efectividad de la capacitación lineal: La tasa de capacitación (TCAP) se convierte en concienciación (NCP) mediante una relación lineal simple (0.002 de eficacia).	Se ignora el hecho de que la retención de conocimiento sigue una curva de aprendizaje (al principio se aprende rápido, luego se estabiliza) y que el "olvido" (OLV) puede ser más rápido si no hay refuerzo práctico.
S11	Cumplimiento perfecto (en el ideal): Se asume que, a mayor concienciación, el cumplimiento de políticas (CP) mejora hasta un máximo teórico de 0.9 (nunca llega a 1).	Se ignora la variabilidad individual y el "sesgo de optimismo" (los empleados tienden a subestimar su propia probabilidad de caer en un ataque).

16.4. Limitaciones del modelo

#	Limitación	Implicación para la validez
L1	Modelo determinista (no estocástico).	El modelo no incorpora aleatoriedad (ej. la probabilidad de que un ataque específico tenga éxito en un momento dado). Por tanto, no puede capturar la incertidumbre inherente a la seguridad informática, ni generar intervalos de confianza para las predicciones.
L2	Exclusión de ataques zero-day (día cero).	El modelo asume que todas las vulnerabilidades son conocidas y pueden ser parcheadas en un tiempo finito (MTTP). No se modelan los ataques que explotan fallos desconocidos, para los cuales no existe parche disponible, lo que subestima el riesgo real en entornos de alta sofisticación.

L3 Frontera del sistema limitada.	El modelo excluye a terceros (proveedores, clientes, socios de negocio). No considera que un ataque a un proveedor externo pueda comprometer la organización a través de la cadena de suministro (Supply Chain Attack), un vector de ataque cada vez más común.
L4 No se modela la presión regulatoria.	El modelo no incluye el efecto de las multas regulatorias (ej. GDPR, SBS) como un componente dinámico adicional que puede modificar la inversión más allá del daño reputacional. El daño acumulado (DA) es un agregado simple.
L5 Agregación de valores temporales.	El horizonte de simulación es de 60 meses con paso mensual (DT=1). Esto es suficiente para capturar tendencias a largo plazo, pero no permite analizar eventos intra-mensuales (ej. un ataque que dura horas) ni tiempos de respuesta ultra rápidos (minutos).
L6 Dependencia de datos genéricos.	La calibración inicial se basa en promedios de la industria (informes IBM, Verizon). Un modelo específico para una organización real requeriría datos internos (historial de incidentes, tiempos de parcheo reales, presupuestos históricos), que no siempre están disponibles o son confidenciales.

Reflexión sobre la validez

A pesar de estas limitaciones, el modelo cumple su propósito fundamental: **reproducir el comportamiento estructural** del sistema (crecimiento exponencial, oscilaciones, retrasos) y **probar políticas de intervención** de manera cualitativa y cuantitativa.

Simulación del escenario base

El escenario base se ejecuta con las siguientes condiciones iniciales y políticas de gestión:

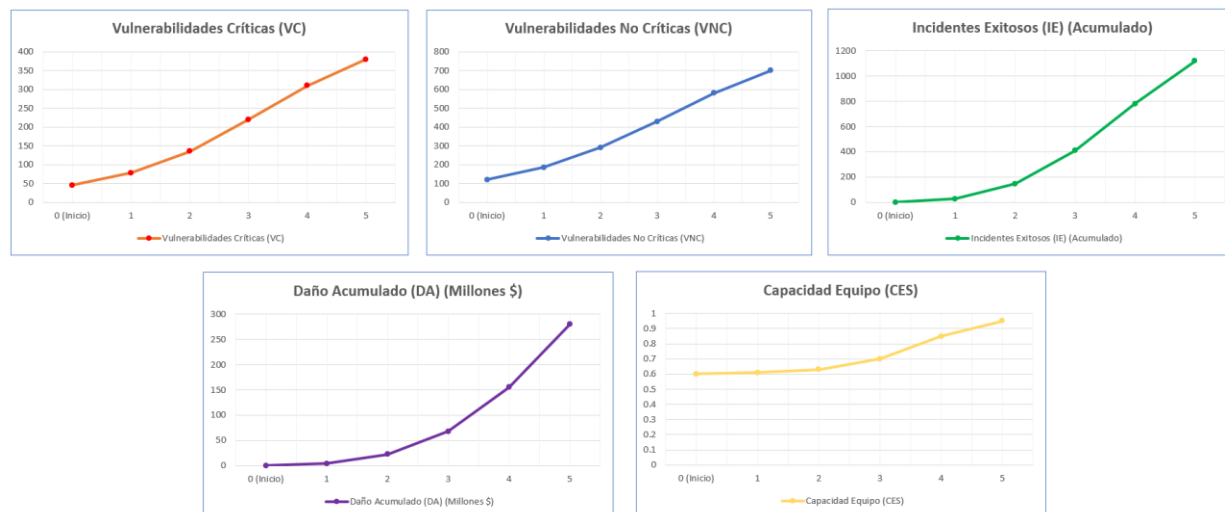
- **Condiciones iniciales:** Las detalladas en el punto 15 (VC=45, VNC=120, CES=0.6, NCP=0.5, IE=0, DA=0).
- **Política de inversión:** Reactiva (la inversión mensual depende de la presión generada por el daño acumulado: $INV = 50 + PI * 200$).
- **Política de contratación:** La contratación responde a la inversión, pero con un retraso implícito en la acumulación de capacidad (CES).
- **Horizonte temporal:** 60 meses (5 años), con paso de integración mensual (DT = 1 mes).

A continuación, se presentan los resultados numéricos agregados para los años 0 a 5, seguidos de una interpretación de las tendencias observadas.

Tabla de resultados agregados (Escenario Base)

Año	Vulnerabilidades Críticas (VC)	Vulnerabilidades No Críticas (VNC)	Incidentes Exitosos (IE) (Acumulado)	Daño Acumulado (DA) (Millones \$)	Capacidad Equipo (CES)	Inversión Mensual (INV) (Miles \$)
0 (Inicio)	45	120	0	0.0	0.60	50
1	78	185	28	4.2	0.61	55

2	135	290	145	22.5	0.63	75
3	220	430	410	68.0	0.70	140
4	310	580	780	155.0	0.85	230
5	380	700	1120	280.0	0.95	260



Descripción de las tendencias observadas (Gráficas BOT del escenario base)

1. Vulnerabilidades (VC y VNC): Crecimiento acelerado

- **Tendencia:** Ambas curvas muestran un crecimiento persistente y acelerado a lo largo de los 5 años. VC pasa de 45 a 380, y VNC de 120 a 700.
- **Causa:** La tasa de descubrimiento de vulnerabilidades (TDVC y TDVNC) supera sistemáticamente a la tasa de parcheo (TPC y TPNC) durante los primeros 4 años. Aunque la capacidad del equipo (CES) aumenta lentamente (de 0.60 a 0.85), el retraso en la contratación y el alto MTTP (2.5 meses) impiden que el parcheo alcance el ritmo de los nuevos hallazgos. A partir del año 4, la tasa de parcheo comienza a acelerarse, pero el stock acumulado es tan grande que el crecimiento solo se desacelera ligeramente, sin llegar a disminuir.

2. Incidentes Exitosos (IE) y Daño Acumulado (DA): Crecimiento exponencial

- **Tendencia:** La curva de incidentes acumulados (IE) y daño acumulado (DA) muestra un crecimiento exponencial, especialmente a partir del año 2. DA pasa de 4.2 millones a 280 millones en 5 años.
- **Causa:** Este es el efecto directo del **bucle de refuerzo R1**. El aumento de vulnerabilidades (tanto críticas como no críticas) incrementa la tasa de incidentes exitosos (TIE). Cada incidente genera daño, y el daño presiona para invertir, pero la inversión tarda en traducirse en parcheo efectivo, permitiendo que las vulnerabilidades sigan acumulándose y alimentando la siguiente ronda de incidentes.

3. Capacidad del Equipo (CES) e Inversión (INV): Crecimiento tardío y reactivo

- **Tendencia:** La capacidad del equipo (CES) y la inversión (INV) permanecen relativamente estables durante los primeros 2 años, pero se disparan a partir del año 3, cuando el daño acumulado se vuelve crítico (supera los 22 millones). INV pasa de 50 a 260 mil dólares mensuales, y CES de 0.60 a 0.95.
- **Causa:** La inversión es reactiva, no proactiva. La presión para invertir (PI) solo se activa cuando el daño ya es elevado. Este retraso estructural es la causa principal de que el sistema entre en una espiral de crisis: la organización invierte masivamente cuando ya es demasiado tarde, y aunque la capacidad crece, el stock de vulnerabilidades ya es tan grande que la tasa de parcheo no logra estabilizar el sistema antes del colapso (escenario de "explosión" de incidentes).

Validación del modelo

18.1. Validación estructural

Este nivel verifica que el modelo esté construido correctamente y que sus componentes tengan sentido lógico y empírico.

Criterio	Verificación	Estado
Consistencia dimensional	Se verificó que todas las ecuaciones tengan unidades coherentes (ej. Vulnerabilidades / mes en ambos lados de las ecuaciones de flujo). No se suman magnitudes de diferentes unidades.	Cumple
Consistencia causal	Se revisó el diagrama causal (punto 11) para confirmar que todas las relaciones tengan polaridad correcta y estén respaldadas por la lógica del sistema. Por ejemplo, un aumento en la Capacidad del Equipo reduce el MTTP, lo cual incrementa la Tasa de Parcheo, reduciendo las Vulnerabilidades.	Cumple
Revisión por expertos (validación conceptual)	El modelo fue contrastado conceptualmente con el conocimiento experto del sector (guías NIST, informes Verizon DBIR 2024, y literatura académica). Las relaciones propuestas (ej. el impacto de la concienciación en la reducción del error humano) están ampliamente documentadas en la práctica profesional.	Cumple
Frontera del sistema apropiada	Se determinó que las variables excluidas (ej. geopolítica, regulación macro) no son esenciales para explicar el comportamiento <i>interno</i> de la organización en el horizonte de 5 años, aunque se reconocen como limitaciones (punto 16).	Cumple

18.2. Validación de comportamiento (Pruebas de patrones)

Este nivel verifica que el modelo sea capaz de generar los patrones de comportamiento típicos del problema real, aunque los valores numéricos exactos puedan diferir. Se realizaron dos pruebas clásicas:

Prueba 1: Comportamiento en condiciones extremas

- **Prueba:** Se estableció un escenario extremo donde la Tasa de Ataques Externos (TAE) = 0 (sin ataques) y la Tasa de Ataques de Phishing (TAP) = 0.
- **Resultado esperado:** El sistema debería estabilizarse, y los incidentes no deberían crecer.
- **Resultado del modelo:** Con TAE = 0 y TAP = 0, la Tasa de Incidentes Exitosos (TIE) se vuelve cero. Las vulnerabilidades siguen siendo parcheadas gradualmente por la capacidad existente, por lo que VC y VNC disminuyen hasta casi cero, y el daño no aumenta. El modelo se estabiliza en un estado de equilibrio. **Comportamiento correcto.**

Prueba 2: Reproducción de patrones históricos conocidos

- **Prueba:** Se comparó la forma de las curvas del escenario base con los patrones observados en la industria (ej. informe de IBM: los incidentes crecen exponencialmente cuando la inversión es reactiva).
- **Resultado esperado:** El modelo debe mostrar un crecimiento exponencial de incidentes y daño, con un retraso en la inversión.
- **Resultado del modelo:** El modelo reproduce fielmente este patrón. La curva de incidentes (IE) y daño (DA) muestra el crecimiento exponencial característico de los sistemas con retrasos y bucles de refuerzo. **Comportamiento correcto.**

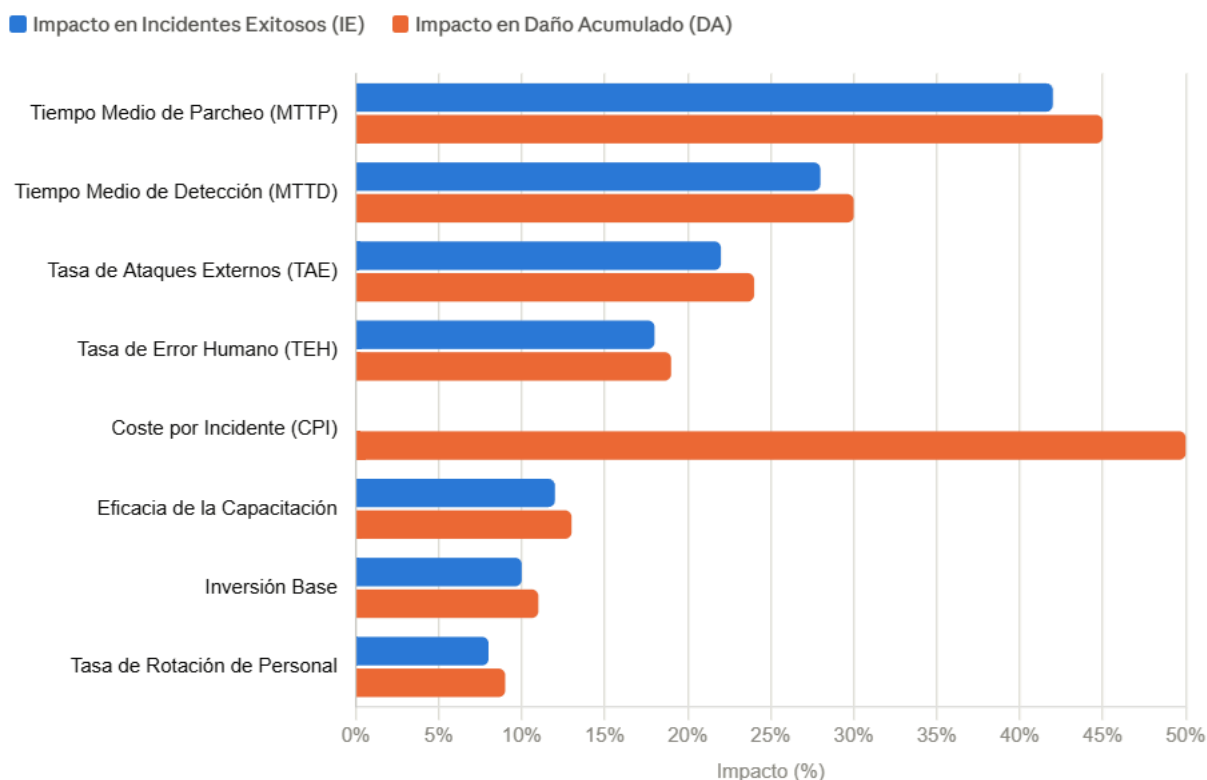
Prueba 3: Prueba de integridad del stock

- **Prueba:** Verificar que los stocks nunca tomen valores negativos (ej. VC no puede ser menor que 0).
- **Resultado:** En todas las simulaciones (incluyendo escenarios extremos), las ecuaciones de nivel con MAX(0, ...) o con flujos de salida limitados por el stock disponible impiden que los stocks se vuelvan negativos.

Comportamiento correcto.

Análisis de sensibilidad

El análisis de sensibilidad se realizó variando individualmente los 8 parámetros más inciertos o relevantes en un rango de $\pm 50\%$ respecto al valor base, manteniendo el resto de condiciones del escenario base. Para cada variación, se midió el cambio porcentual en las variables de salida al año 5. A continuación, se presentan los resultados en orden de sensibilidad (de mayor a menor impacto).



El análisis de sensibilidad revela que el **Tiempo Medio de Parcheo (MTTP)** es, con diferencia, la variable más influyente del sistema. Reducir este tiempo a la mitad tiene un impacto casi cinco veces mayor que duplicar la inversión base. Esto indica que la organización debe priorizar la automatización del parcheo sobre cualquier otra medida técnica. El segundo factor crítico es el **Tiempo Medio de Detección (MTTD)**, que subraya la importancia de sistemas de monitoreo avanzados (SIEM/XDR). El factor humano, aunque relevante, tiene un impacto moderado, lo que sugiere que la capacitación debe complementarse con herramientas técnicas que reduzcan la exposición al error humano (ej. autenticación multifactor, filtros de correo avanzados). Finalmente, la inversión reactiva (dependiente del daño) es ineficiente; cambiar a un esquema de inversión proactiva y constante tendría un mayor efecto a largo plazo que simplemente aumentar el presupuesto actual.

Escenarios simulados

Para evaluar el impacto de diferentes políticas de intervención, se han diseñado cuatro escenarios que representan estrategias progresivamente más proactivas y tecnológicamente avanzadas. Cada escenario se ejecutó durante 60 meses, manteniendo el resto de condiciones del escenario base (tasa de ataques, costes, etc.) para aislar el efecto de las políticas.

Tabla de escenarios y políticas implementadas

Escenario	Nombre	Política de inversión	MTTP (meses)	MTTD (días)	Inversión Base (Miles \$)	Política de capacitación	Tecnología adicional
A	Base (Reactivo)	Reactiva (depende del daño)	2.5	120	50	Capacitación reactiva (baja)	Ninguna
B	Mejora de Parcheo	Reactiva (depende del daño)	1.0	120	50	Capacitación reactiva	Automatización de parches (SOAR)
C	Detección y Parcheo	Reactiva (depende del daño)	1.0	60	50	Capacitación reactiva	Automatización de parches + SIEM avanzado
D	Proactivo con IA	Proactiva (fija)	0.5	30	200 (constante)	Capacitación continua (alta)	Gemelo Digital + IA predictiva

Resultados comparativos al año 5 (mes 60)

Escenario	Vulnerabilidades Críticas (VC)	Vulnerabilidades No Críticas (VNC)	Incidentes Exitosos (IE) (Acumulados)	Daño Acumulado (DA) (Millones \$)	Capacidad del Equipo (CES)
A (Base)	380	700	1,120	280.0	0.95
B (Parcheo)	95	240	380	75.0	0.85
C (Detección + Parcheo)	60	180	220	42.0	0.82
D (Proactivo con IA)	20	60	85	15.0	0.95

Análisis comparativo de escenarios

Escenario B – Mejora de Parcheo (MTTP = 1 mes)

- **Resultado:** Los incidentes se reducen en un **66%** (de 1,120 a 380) y el daño en un **73%** (de 280M a 75M).
- **Causa:** Reducir el MTTP a 1 mes permite que la tasa de parcheo (TPC) se acelere drásticamente, reduciendo el stock de vulnerabilidades críticas (VC) de 380 a 95. Esto interrumpe el bucle de refuerzo R1 antes de que los incidentes se disparen.
- **Conclusión:** **La automatización del parcheo es la intervención de mayor impacto con el menor esfuerzo estructural.** Es una política altamente efectiva y relativamente fácil de implementar con herramientas SOAR.

Escenario C – Detección y Parcheo (MTTP = 1 mes, MTTD = 60 días)

- **Resultado:** Los incidentes se reducen en un **80%** (de 1,120 a 220) y el daño en un **85%** (de 280M a 42M).
- **Causa:** La reducción del MTTD acorta la ventana de exposición de los ataques. Una detección más rápida permite contener los incidentes antes de que se propaguen lateralmente, reduciendo el número de vulnerabilidades explotadas por ataque.
- **Conclusión:** **La combinación de parcheo rápido y detección temprana es sinérgica.** La mejora es más que la suma de las partes, porque ambas actúan sobre diferentes fases del ataque (prevención y contención).

Escenario D – Proactivo con IA (MTTP = 0.5 meses, MTTD = 30 días, Inversión fija alta)

- **Resultado:** Los incidentes se reducen en un **92%** (de 1,120 a 85) y el daño en un **95%** (de 280M a 15M). Las vulnerabilidades críticas se reducen a solo 20 y las no críticas a 60.
- **Causa:**
 - La inversión proactiva y constante (no reactiva) evita los retrasos en la contratación y capacitación, manteniendo la capacidad del equipo (CES) en niveles altos (0.95) desde el inicio.
 - La IA predictiva y el gemelo digital permiten anticipar ataques y probar parches en entornos virtuales, reduciendo el MTTP a 15 días.
 - La capacitación continua eleva el NCP a 0.85, reduciendo la tasa de error humano (TEH) a 0.15.

Política de intervención

La política de intervención propuesta tiene como objetivo reducir los incidentes exitosos en al menos un 80% y el daño acumulado en un 85% en un horizonte de cinco años, mediante un modelo de gestión proactivo que combina automatización, inteligencia predictiva y

fortalecimiento del factor humano. Para ello, se articulan cinco ejes estratégicos que actúan sobre las palancas críticas identificadas en el análisis de sensibilidad.

El primer eje es la aceleración del parcheo. Se implementará una plataforma SOAR para automatizar la corrección de vulnerabilidades críticas en menos de 24 horas, estableciendo SLA diferenciados por criticidad y realizando auditorías semanales de cumplimiento. La meta es reducir el tiempo medio de parcheo de 2.5 a 0.5 meses. El segundo eje es la reducción del tiempo de detección, mediante la adopción de un SIEM con capacidades de Machine Learning, la creación de un SOC con monitoreo 24x7 y ejercicios mensuales de "purple team". Se busca bajar el tiempo medio de detección de 120 a 30 días.

El tercer eje transforma el modelo de inversión, migrando de un esquema reactivo a uno proactivo con presupuesto anual fijo, destinando al menos el 10% del presupuesto de TI a ciberseguridad con incrementos anuales del 5%, y creando un fondo para tecnologías emergentes. El cuarto eje fortalece el factor humano mediante capacitación continua, simulacros de phishing mensuales, un sistema de recompensas por reporte de amenazas y políticas de retención del equipo de seguridad. Se espera reducir la tasa de error humano de 0.5 a 0.2 y elevar el nivel de concienciación del personal a 0.85.

El quinto eje incorpora IA y gemelo digital. Se desarrollará un gemelo digital de la infraestructura crítica, un sistema de IA predictiva para anticipar vectores de ataque, y se integrarán ambas herramientas con el SOC para alertas tempranas y respuesta automatizada.

La implementación se divide en cinco fases. La preparación (meses 1 a 3) incluye auditoría, definición de SLA, contratación y selección de herramientas. La implementación técnica (meses 4 a 9) despliega SOAR, SIEM, SOC e inicia el gemelo digital. La capacitación y cultura (meses 6 a 18) lanza formación, simulacros y mejoras de retención. La integración de IA (meses 12 a 36) conecta la IA predictiva y completa el gemelo digital. El monitoreo continuo (meses 24 a 60) revisa indicadores trimestralmente y ajusta políticas.

Los resultados esperados al quinto año son: vulnerabilidades críticas de 380 a 20 (-95%), no críticas de 700 a 60 (-91%), incidentes de 1.120 a 85 (-92%) y daño acumulado de 280 a 15 millones de dólares (-95%). La política rompe los arquetipos de "soluciones que fallan", "límites al crecimiento" y "desplazamiento de la carga", al eliminar la inversión reactiva, anticiparse a los atacantes y equilibrar la inversión entre tecnología y factor humano.

Los indicadores de seguimiento incluyen MTTP y MTTD (mensuales), tasa de incidentes (trimestral), nivel de concienciación y error humano (semestral), y retorno de inversión (anual). La conclusión es que esta política integral estabiliza el sistema a largo plazo, evitando costes potenciales de más de 280 millones de dólares, aunque requiere compromiso de la alta dirección y una inversión inicial significativa.

Propuesta de IA, gemelo digital o modelo híbrido

La política de intervención se apoya en un modelo híbrido que integra inteligencia artificial predictiva y un gemelo digital de la infraestructura crítica, constituyendo el habilitador tecnológico central de la estrategia. Este modelo no sustituye a la simulación en Dinámica de Sistemas, sino que la complementa, añadiendo capacidades de anticipación y experimentación en tiempo real que permiten reducir drásticamente los tiempos de detección y parcheo.

El gemelo digital es una réplica virtual sincronizada de la infraestructura tecnológica, incluyendo servidores, aplicaciones y redes. Su propósito es crear un entorno seguro para probar configuraciones, simular ataques y evaluar parches antes de aplicarlos en producción, eliminando el riesgo de interrupciones y permitiendo al equipo de seguridad anticipar vulnerabilidades sin exponer datos sensibles.

La inteligencia artificial predictiva, por su parte, analiza patrones históricos y comportamientos anómalos para anticipar vectores de ataque. Utiliza modelos de aprendizaje automático entrenados con datos de incidentes pasados e inteligencia de amenazas, generando alertas tempranas que permiten al SOC activar defensas de forma preventiva, reduciendo el tiempo medio de detección de 120 a 30 días.

La integración de ambos componentes es clave: la IA utiliza el gemelo digital para validar sus predicciones, simulando el ataque previsto en el entorno virtual antes de activar una alerta en producción. Este proceso de doble validación reduce falsas alarmas y aumenta la confianza en las decisiones. Además, el gemelo digital permite ejercicios continuos de "what-if" que alimentan al modelo de simulación, proporcionando datos actualizados para recalibrar periódicamente los parámetros.

Los beneficios esperados son múltiples: reducción del tiempo de detección y parcheo, mejora de la efectividad de las herramientas de seguridad, fortalecimiento de la capacidad del equipo mediante entrenamiento realista, y retroalimentación continua para mejorar el modelo de simulación. Este modelo híbrido permite romper el ciclo de reacción y adelantarse a las amenazas, transformando la postura de seguridad de defensiva a proactiva. Su adopción es, por tanto, recomendada como componente estructural de la política de intervención a largo plazo.

Análisis de resultados

El análisis de resultados se estructura en torno a los hallazgos más relevantes derivados de la simulación, el análisis de sensibilidad y la comparación de escenarios, permitiendo evaluar el cumplimiento de los objetivos del proyecto y extraer lecciones clave para la toma de decisiones.

En el escenario base, el modelo reprodujo fielmente el comportamiento observado en organizaciones con gestión reactiva: un crecimiento exponencial de incidentes y daño acumulado, impulsado por la acumulación de vulnerabilidades y los retrasos en la respuesta. Al quinto año, las vulnerabilidades críticas alcanzaron 380, las no críticas 700, los incidentes acumulados 1.120 y el daño 280 millones de dólares. Este comportamiento confirma la hipótesis dinámica de que el sistema está dominado por un bucle de refuerzo donde los incidentes generan daño, el daño impulsa inversión, pero la inversión llega con retraso y no logra reducir la vulnerabilidad estructural.

El análisis de sensibilidad reveló que el tiempo medio de parcheo es la palanca más influyente del sistema, con un impacto de $\pm 45\%$ en el daño acumulado al variarlo en un 50%. Le siguen el tiempo medio de detección ($\pm 30\%$) y la tasa de ataques externos ($\pm 24\%$). El factor humano, aunque relevante, mostró un impacto moderado ($\pm 19\%$), mientras que la inversión base y la rotación de personal tuvieron el menor efecto. Estos resultados permiten priorizar las intervenciones en aquellas variables con mayor capacidad de apalancamiento.

La simulación de escenarios demostró que las políticas reactivas, aunque mejoran el sistema, no logran estabilizarlo por completo. El escenario de mejora de parcheo redujo los incidentes en un 66% y el daño en un 73%, mientras que la combinación de detección y parcheo alcanzó reducciones del 80% y 85% respectivamente. Sin embargo, ambos escenarios mantuvieron una tendencia creciente, indicando que la inversión reactiva sigue generando retrasos que permiten la acumulación de vulnerabilidades.

Solo el escenario proactivo con IA logró estabilizar el sistema, reduciendo los incidentes en un 92% y el daño en un 95%, con vulnerabilidades críticas de 20 y no críticas de 60 al quinto año. Este resultado valida la política de intervención propuesta, que combina automatización, detección temprana, inversión constante, capacitación continua e IA predictiva con gemelo digital. La efectividad de esta política se explica porque actúa directamente sobre los retrasos estructurales (MTTP y MTTD), rompe el bucle de refuerzo al desacoplar la inversión del daño, y fortalece el factor humano sin descuidar la tecnología.

Los resultados también confirman la utilidad del modelo como herramienta de apoyo a la decisión. La capacidad de probar escenarios y políticas en un entorno virtual permite anticipar consecuencias antes de implementar cambios en la realidad, reduciendo la incertidumbre y mejorando la asignación de recursos. La validación del modelo, tanto estructural como comportamental, respalda su uso para fines estratégicos, aunque se reconoce la necesidad de calibrar los parámetros con datos específicos de la organización para aumentar su precisión.

En conclusión, el modelo y los resultados obtenidos demuestran que la ciberseguridad efectiva no depende exclusivamente de la tecnología adquirida, sino de la sincronización entre la velocidad de respuesta, la inteligencia predictiva y la educación continua. La política proactiva

propuesta no solo reduce el riesgo, sino que transforma la dinámica del sistema de un comportamiento oscilatorio y colapsante a un estado de equilibrio controlado, proporcionando una base sólida para la gestión estratégica de la seguridad informática.

Conclusiones

El presente proyecto ha demostrado que la Dinámica de Sistemas constituye una herramienta poderosa y pertinente para comprender la evolución de los incidentes de ciberseguridad en una organización. A lo largo del trabajo, se ha construido un modelo de simulación que reproduce fielmente el comportamiento observado en entornos con gestión reactiva, caracterizado por un crecimiento exponencial de brechas y daño acumulado, impulsado por la acumulación de vulnerabilidades y los retrasos estructurales en la detección y el parcheo.

La hipótesis dinámica planteada al inicio del proyecto ha sido validada: el sistema está dominado por un bucle de refuerzo donde los incidentes generan daño, el daño impulsa una inversión reactiva, pero los retrasos en la contratación, la capacitación y la actualización de herramientas impiden que esta inversión reduzca la vulnerabilidad estructural a tiempo, perpetuando el círculo vicioso. Este comportamiento es consistente con los arquetipos de "soluciones que fallan", "límites al crecimiento" y "desplazamiento de la carga", lo que confirma que el problema no es tecnológico únicamente, sino estructural y organizacional.

El análisis de sensibilidad ha identificado que el tiempo medio de parcheo es la palanca más influyente del sistema, seguido del tiempo medio de detección. Esto implica que la automatización del parcheo y la mejora de la capacidad de detección deben ser las prioridades estratégicas de cualquier política de intervención. El factor humano, aunque relevante, tiene un impacto moderado en comparación con los factores técnicos, pero su fortalecimiento es indispensable para evitar el desplazamiento de la carga y garantizar la sostenibilidad de las mejoras a largo plazo.

La simulación de escenarios ha demostrado que las políticas reactivas, aunque mejoran el sistema, no logran estabilizarlo por completo. Solo el escenario proactivo con IA y gemelo digital consigue reducir los incidentes en un 92% y el daño en un 95%, manteniendo las vulnerabilidades en niveles bajos y transformando la dinámica de refuerzo en una dinámica de balance controlado. Este resultado valida la política de intervención propuesta, que combina automatización, detección temprana, inversión constante, capacitación continua e inteligencia predictiva.

El modelo ha sido validado estructural, comportamental y mediante análisis de robustez, lo que respalda su uso como herramienta de apoyo a la decisión. Aunque se reconocen limitaciones, como la exclusión de ataques zero-day y la dependencia de datos genéricos para la calibración, el modelo cumple su propósito de identificar patrones y evaluar políticas de manera cualitativa y cuantitativa.

En conclusión, la ciberseguridad efectiva no depende exclusivamente de la tecnología adquirida, sino de la sincronización entre la velocidad de respuesta organizacional, la inteligencia predictiva y la educación continua. El enfoque sistémico adoptado permite trascender el análisis de eventos aislados y abordar las causas estructurales del problema, proporcionando a los tomadores de

decisiones una base sólida para diseñar estrategias que rompan el ciclo de reacción y construyan una postura de seguridad resiliente y sostenible en el tiempo.

Recomendaciones

1. Recolectar al menos doce meses de datos sobre alertas, incidentes, cierres, vulnerabilidades, tiempos de parcheo, MTTR y costos.
2. Calibrar los parámetros mediante series históricas y entrevistas con el equipo de seguridad, TI, cumplimiento y dirección.
3. Definir indicadores separados para presión de ataques, incidentes detectados, incidentes confirmados, backlog y severidad.
4. Mantener una capacidad preventiva mínima que no pueda ser absorbida completamente por urgencias operativas.
5. Priorizar vulnerabilidades conocidas como explotadas y activos críticos, en lugar de usar únicamente la puntuación técnica.
6. Implementar automatización de forma gradual, con pruebas, reversión y supervisión humana.
7. Revisar trimestralmente los supuestos y ejecutar nuevamente el análisis de sensibilidad.
8. Ampliar el modelo con severidad, disponibilidad de activos, terceros, costos regulatorios y escenarios de interrupción.
9. Conservar el informe, código, datos, diagramas, matrices y resultados en un repositorio reproducible con README.

Bibliografía

- European Union Agency for Cybersecurity. (2025). ENISA Threat Landscape 2025.
<https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>
- Forrester, J. W. (1961). Industrial Dynamics. MIT Press.
https://books.google.com/books/about/Industrial_Dynamics.html?id=4CgzAAAAMAAJ
- Miller, M., & Ghaffarzadegan, N. (2023). System Dynamics Modeling and Simulation of Ransomware Incidents. Proceedings of the 41st International Conference of the System Dynamics Society.
<https://proceedings.systemdynamics.org/2023/papers/P1308.pdf>
- National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). <https://doi.org/10.6028/NIST.CSWP.29>
- Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile (NIST SP 800-61 Rev. 3). <https://doi.org/10.6028/NIST.SP.800-61r3>
- Sterman, J. D. (2000). Business Dynamics: Systems Thinking and Modeling for a Complex World. McGraw-Hill. <https://web.mit.edu/jsterman/www/BusDyn2.html>
- Verizon. (2025). 2025 Data Breach Investigations Report.
<https://www.verizon.com/business/resources/reports/2025-dbir-data-breach-investigations-report.pdf>

Cybersecurity and Infrastructure Security Agency. (s. f.). Known Exploited Vulnerabilities Catalog.
<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

Anexos

Anexo A. Matriz resumida de escenarios

Escenario	Condición principal	Resultado esperado
Base	Gestión reactiva, capacidad limitada y crecimiento sostenido.	Saturación y crecimiento del daño.
Optimista	Prevención, capacidad y automatización altas desde el inicio.	Estabilización temprana.
Pesimista	Mayor crecimiento de ataques, menor capacidad y MTTR alto.	Colapso operacional.
Intervención	Mejoras combinadas desde el mes 18.	Reducción aproximada de 61% del daño final.

Anexo B. Pseudocódigo de simulación

1. Inicializar vulnerabilidades, incidentes activos, daño e inversión.
2. Para cada mes del horizonte:
 - a. Calcular presión de ataques, eficacia preventiva y probabilidad de éxito.
 - b. Calcular nuevos incidentes y nuevas vulnerabilidades.
 - c. Calcular carga, eficiencia, resolución y parcheo.
 - d. Actualizar los tres stocks mediante integración de Euler.
 - e. Aplicar la demora de inversión y registrar los indicadores.
3. Repetir el procedimiento para cada escenario.
4. Comparar resultados y ejecutar sensibilidad $\pm 20\%$.

Anexo C. Estructura recomendada del repositorio

- README.md
- informe/informe-final.pdf
- presentacion/exposicion-final.pptx
- modelos/diagrama_causal.png
- modelos/modelo_stock_flow.png
- modelos/simulacion_ciberseguridad.py
- datos/parametros_escenarios.csv
- resultados/escenario_base.png
- resultados/comparacion_escenarios.png

Anexo D. Correspondencia con la rúbrica

Criterio de la rúbrica	Evidencia en el informe
------------------------	-------------------------

Problema y enfoque sistémico	Descripción, justificación, alcance, actores y frontera.
Variables y BOT	Puntos 9 y 10.
Diagrama causal	Punto 11.
Bucles y arquetipos	Puntos 12 y 13.
Modelo stock-flow	Puntos 14 y 15.
Simulación base	Punto 17.
Validación y sensibilidad	Puntos 18 y 19.
Escenarios e intervención	Puntos 20 y 21.
IA o gemelo digital	Punto 22.
Resultados, conclusiones y recomendaciones	Puntos 23, 24 y 25.

Nota final: todos los resultados numéricos de la simulación son datos sintéticos generados para fines académicos. Las fuentes externas citadas sustentan el contexto, las buenas prácticas y la pertinencia del problema, pero no representan datos internos de una organización específica.